



Fortify Standalone Report Generator

Developer Workbook

odoo_KNhfAReLX2



Table of Contents

[Executive Summary](#)

[Project Description](#)

[Issue Breakdown by Fortify Categories](#)

[Results Outline](#)

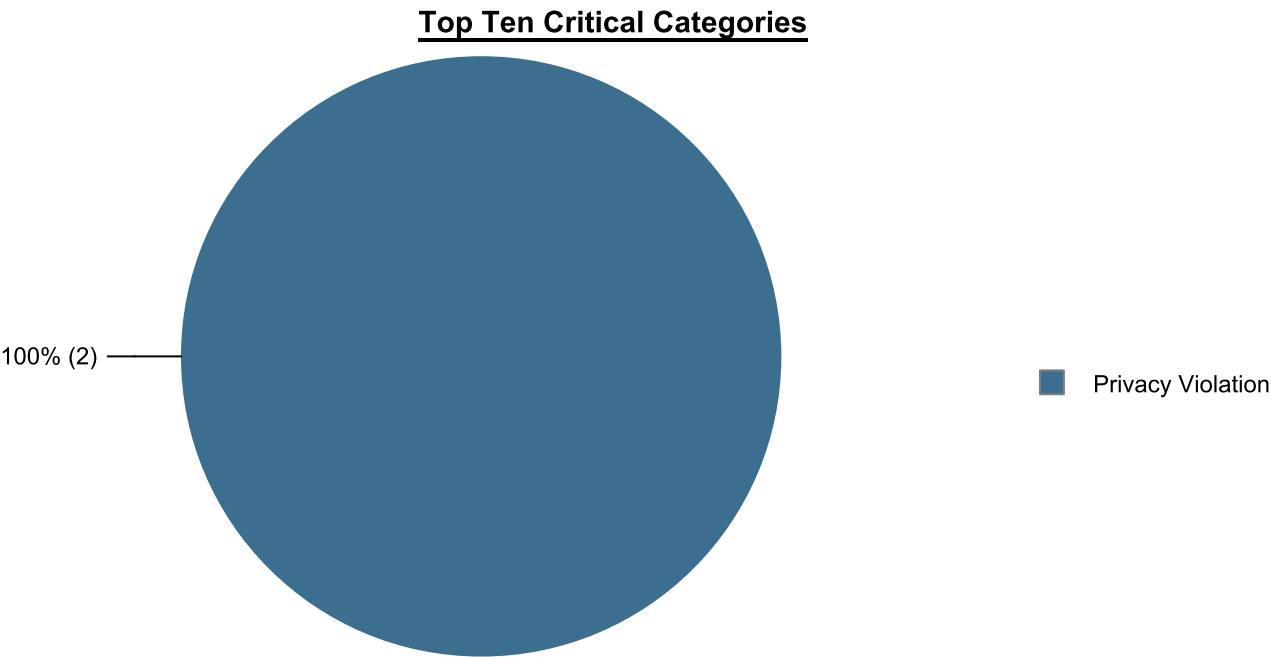
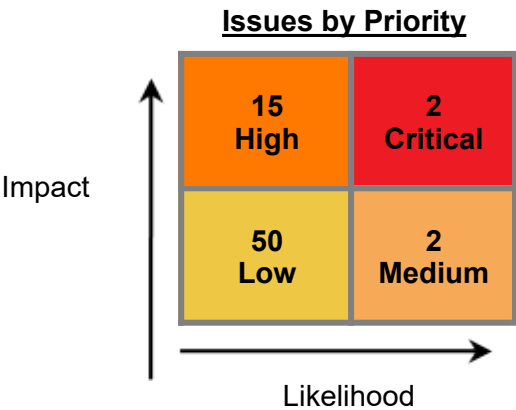


Executive Summary

This workbook is intended to provide all necessary details and information for a developer to understand and remediate the different issues discovered during the odoo_KNhfAReLX2 project audit. The information contained in this workbook is targeted at project managers and developers.

This section provides an overview of the issues uncovered during analysis.

Project Name:	odoo_KNhfAReLX2
Project Version:	
SCA:	Results Present
WebInspect:	Results Not Present
WebInspect Agent:	Results Not Present
Other:	Results Not Present



Project Description

This section provides an overview of the Fortify scan engines used for this project, as well as the project meta-information.

SCA

Date of Last Analysis:	Jul 13, 2024 9:14 AM	Engine Version:	23.1.0.0136
Host Name:	ETC_ITI_ScanCode	Certification:	VALID
Number of Files:	1,626	Lines of Code:	91,833
Rulepack Name		Rulepack Version	
Fortify Secure Coding Rules, Community, Cloud		2023.4.0.0006	
Fortify Secure Coding Rules, Community, Universal		2023.4.0.0006	
Fortify Secure Coding Rules, Core, Cloud		2023.4.0.0006	
Fortify Secure Coding Rules, Core, JavaScript		2023.4.0.0006	
Fortify Secure Coding Rules, Core, Python		2023.4.0.0006	
Fortify Secure Coding Rules, Core, Universal		2023.4.0.0006	
Fortify Secure Coding Rules, Extended, Configuration		2023.4.0.0006	
Fortify Secure Coding Rules, Extended, Content		2023.4.0.0006	
Fortify Secure Coding Rules, Extended, JavaScript		2023.4.0.0006	



Issue Breakdown by Fortify Categories

The following table depicts a summary of all issues grouped vertically by Fortify Category. For each category, the total number of issues is shown by Fortify Priority Order, including information about the number of audited issues.

Category	Fortify Priority (audited/total)				Total Issues
	Critical	High	Medium	Low	
Cross-Site Request Forgery	0	0	0	0 / 2	0 / 2
Dockerfile Misconfiguration: Dependency Confusion	0	0 / 3	0	0	0 / 3
Dockerfile Misconfiguration: Sensitive Host Directory	0	0	0	0 / 1	0 / 1
Hardcoded Domain in HTML	0	0	0	0 / 3	0 / 3
Insecure Randomness	0	0 / 5	0	0	0 / 5
Password Management: Empty Password	0	0 / 1	0	0	0 / 1
Password Management: Hardcoded Password	0	0 / 5	0	0	0 / 5
Password Management: Password in Comment	0	0	0	0 / 9	0 / 9
Path Manipulation	0	0 / 1	0	0	0 / 1
Poor Error Handling: Empty Catch Block	0	0	0	0 / 13	0 / 13
Portability Flaw: File Separator	0	0	0 / 2	0	0 / 2
Privacy Violation	0 / 2	0	0	0	0 / 2
System Information Leak: Internal	0	0	0	0 / 21	0 / 21
Weak Cryptographic Hash	0	0	0	0 / 1	0 / 1



Results Outline

Cross-Site Request Forgery (2 issues)

Abstract

HTTP requests must contain a user-specific secret to prevent an attacker from making unauthorized requests.

Explanation

A cross-site request forgery (CSRF) vulnerability occurs when: 1. A web application uses session cookies. 2. The application acts on an HTTP request without verifying that the request was made with the user's consent. A nonce is a cryptographic random value that is sent with a message to prevent replay attacks. If the request does not contain a nonce that proves its provenance, the code that handles the request is vulnerable to a CSRF attack (unless it does not change the state of the application). This means a web application that uses session cookies has to take special precautions to ensure that an attacker can't trick users into submitting bogus requests. Imagine a web application that allows administrators to create new accounts as follows:

```
var req = new XMLHttpRequest();
req.open("POST", "/new_user", true);
body = addToPost(body, new_username);
body = addToPost(body, new_passwd);
req.send(body);
```

An attacker might set up a malicious web site that contains the following code.

```
var req = new XMLHttpRequest();
req.open("POST", "http://www.example.com/new_user", true);
body = addToPost(body, "attacker");
body = addToPost(body, "haha");
req.send(body);
```

If an administrator for example.com visits the malicious page while she has an active session on the site, she will unwittingly create an account for the attacker. This is a CSRF attack. It is possible because the application does not have a way to determine the provenance of the request. Any request could be a legitimate action chosen by the user or a faked action set up by an attacker. The attacker does not get to see the Web page that the bogus request generates, so the attack technique is only useful for requests that alter the state of the application. Applications that pass the session identifier in the URL rather than as a cookie do not have CSRF problems because there is no way for the attacker to access the session identifier and include it as part of the bogus request. CSRF is entry number five on the 2007 OWASP Top 10 list.

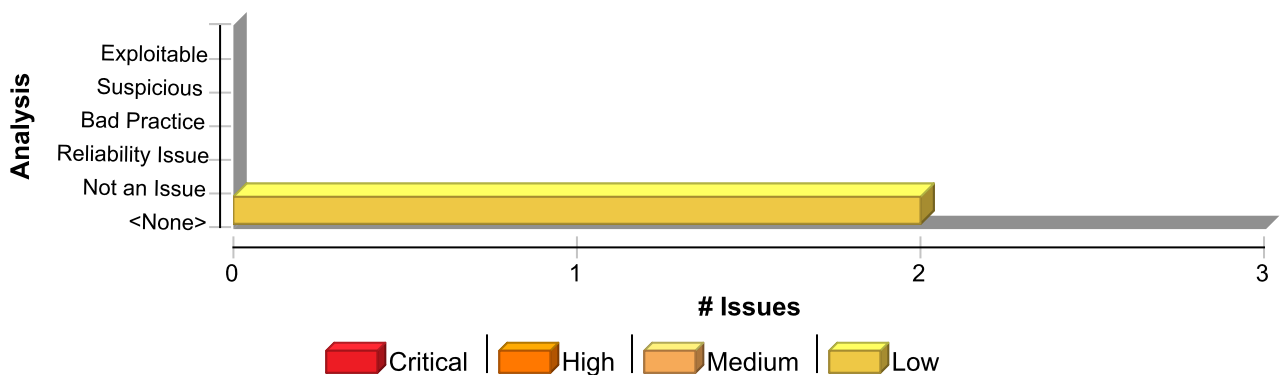
Recommendation

Applications that use session cookies must include some piece of information in every form post that the back-end code can use to validate the provenance of the request. One way to do that is to include a random request identifier or nonce, as follows:

```
RequestBuilder rb = new RequestBuilder(RequestBuilder.POST, "/new_user");
body = addToPost(body, new_username);
body = addToPost(body, new_passwd);
body = addToPost(body, request_id);
rb.sendRequest(body, new NewAccountCallback(callback));
```

Then the back-end logic can validate the request identifier before processing the rest of the form data. When possible, the request identifier should be unique to each server request rather than shared across every request for a particular session. As with session identifiers, the harder it is for an attacker to guess the request identifier, the harder it is to conduct a successful CSRF attack. The token should not be easily guessed and it should be protected in the same way that session tokens are protected, such as using SSLv3. Additional mitigation techniques include: **Framework protection:** Most modern web application frameworks embed CSRF protection and they will automatically include and verify CSRF tokens. **Use a Challenge-Response control:** Forcing the customer to respond to a challenge sent by the server is a strong defense against CSRF. Some of the challenges that can be used for this purpose are: CAPTCHAs, password re-authentication and one-time tokens. **Check HTTP Referer/Origin headers:** An attacker won't be able to spoof these headers while performing a CSRF attack. This makes these headers a useful method to prevent CSRF attacks. **Double-submit Session Cookie:** Sending the session ID Cookie as a hidden form value in addition to the actual session ID Cookie is a good protection against CSRF attacks. The server will check both values and make sure they are identical before processing the rest of the form data. If an attacker submits a form in behalf of a user, he won't be able to modify the session ID cookie value as per the same-origin-policy. **Limit Session Lifetime:** When accessing protected resources using a CSRF attack, the attack will only be valid as long as the session ID sent as part of the attack is still valid on the server. Limiting the Session lifetime will reduce the probability of a successful attack. The techniques described here can be defeated with XSS attacks. Effective CSRF mitigation includes XSS mitigation techniques.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Cross-Site Request Forgery	2	0	0	2
Total	2	0	0	2



Cross-Site Request Forgery

Low

Package: .src.js

addons/etc_asset/static/src/js/socket_client.js, line 1333 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: Request()

File: addons/etc_asset/static/src/js/socket_client.js:1333

Taint Flags:

```
1330  _this8 = _super2.call(this);
1331  installTimerFunctions(_assertThisInitialized(_this8), opts);
1332  _this8.opts = opts;
1333  _this8.method = opts.method || "GET";
1334  _this8.uri = uri;
1335  _this8.async = false !== opts.async;
1336  _this8.data = undefined !== opts.data ? opts.data : null;
```

addons/etc_asset/static/src/js/socket_client.js, line 1284 (Cross-Site Request Forgery)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Structural)

Sink Details

Sink: AssignmentStatement

Enclosing Method: doWrite()

File: addons/etc_asset/static/src/js/socket_client.js:1284

Taint Flags:

```
1281  var _this6 = this;
1282
1283  var req = this.request({
1284    method: "POST",
1285    data: data
1286  });
1287  req.on("success", fn);
```



Dockerfile Misconfiguration: Dependency Confusion (3 issues)

Abstract

Retrieving build dependencies using a non-specific version can leave the build system vulnerable to malicious binaries or cause the system to experience unexpected behavior.

Explanation

Dockerfiles can specify an unbound range of versions for dependencies and base images. If an attacker is able to add malicious versions of dependencies to a repository or trick the build system into downloading dependencies from a repository under the attacker's control, if docker is configured without specific versions of dependencies, then docker will silently download and run the compromised dependency. This type of weakness would be exploitable as a result of a supply chain attack where attackers can leverage misconfiguration by developers, typosquatting and can add malicious packages to open source repositories. An attack of this type exploits the trust in the published packages to gain access and exfiltrate data. In docker, the latest tag automatically indicates the version level of an image that doesn't use a digest or unique tag to provide a version for it. Docker automatically assigns the latest tag as mechanism to point to the most recent image manifest file. Because tags are mutable, an attacker can replace an image or layer using a latest (or weak tags such as imagename-lst, imagename-last, myimage).

Example 1: The following configuration instructs Docker to pick the base image using the latest version of ubuntu.

```
FROM ubuntu:Latest
```

```
...
```

Docker does not validate whether the repository configured to support the package manager is trustworthy.

Example 2: The following configuration instructs the package manager zypper to retrieve the latest version of the given package.

```
...
zypper install package
```

```
...
```

In Example 2, if the repository is compromised, an attacker could simply upload a version that meets the dynamic criteria and cause zypper to download a malicious version of the dependency.

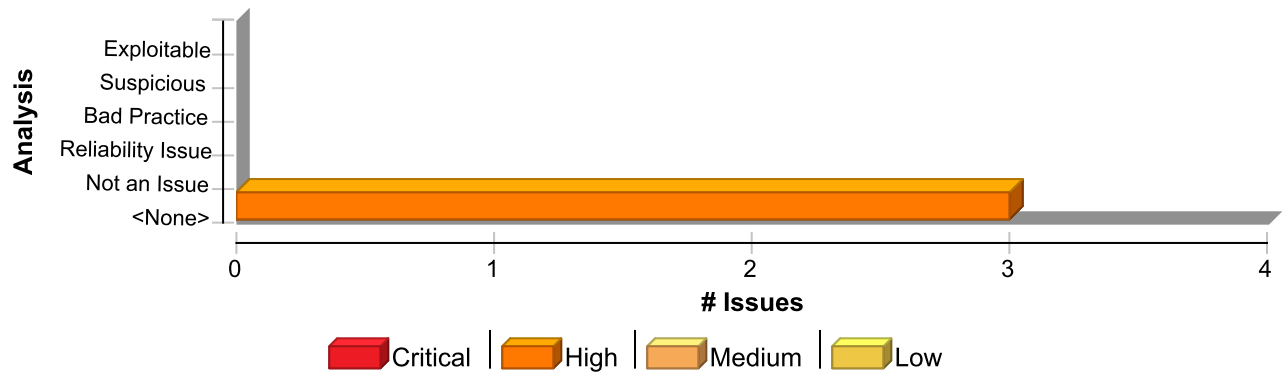
Recommendation

Perform version pinning or simple pinning. Version pinning explicitly specifies the version of images, libraries and support packages an application or system depends on. The primary goal of pinning is to ensure system stability to achieve repeatable deployments. Pinning ensures that end-users, developers, and testers all use the same code base. Pinning can additionally ensure the use of safe dependencies; those which have gone through the rigorous process of application security validation and malware detection. When you invoke zypper (or other package managers) from docker, use the following formats:

```
RUN zypper install <package_name>=<version> \  
RUN gem install <package_name> --version <version>  
RUN gem install <package_name> -v <version>  
RUN apk add <package_name>=<version>  
RUN apt-get update && apt-get install -y \  
    <package_name>=<version> \  
    <package_name>=<version> \  
    <package_name>=<version> \  
&& rm -rf /var/lib/apt/lists/*
```

Where is the name of the dependency to install and is the exact version or release the application should use. Fortify also recommends: - Ensure the repositories that the package managers use are trustworthy or that they are properly kept, and there is no install package substitution possible, including the addition of malicious code onto the package. - Avoid using public or untrusted repositories. - Scan packages for malware and security vulnerabilities prior to executing any regression tests. - Use digitally signed images. - Avoid using image tags such as latest or weak tags such as imagename-lst, imagename-last, myimage for deployments in production environments. - Stick to more stable tags, like specific version tags, although there is no guarantee that these cannot mutate either. - Do not create mutant tags. - Implement strict control over the source of images and their layers.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Dockerfile Misconfiguration: Dependency Confusion	3	0	0	3
Total	3	0	0	3

Dockerfile Misconfiguration: Dependency ConfusionHigh

Package: ciccicd/Dockerfile.odoo, line 15 (Dockerfile Misconfiguration: Dependency Confusion)

Issue Details



Dockerfile Misconfiguration: Dependency Confusion

High

Package: cicc

cicc/Dockerfile.odoo, line 15 (Dockerfile Misconfiguration: Dependency Confusion)

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details

Sink: RUN

File: cicc/Dockerfile.odoo:15

Taint Flags:

```
12 # Fortify Suppress: Dependency Confusion - Package versions are determined by
13 # the pinned base image (debian:bullseye-20240211-slim). Using a date-pinned
14 # base image ensures reproducible builds with consistent package versions.
15 RUN apt-get update && \
16 apt-get install -y --no-install-recommends \
17 ca-certificates \
18 curl \
```

cicc/Dockerfile.odoo, line 60 (Dockerfile Misconfiguration: Dependency Confusion)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details

Sink: RUN

File: cicc/Dockerfile.odoo:60

Taint Flags:

```
57 && pip3 install -r /tmp/requirements.txt --no-cache-dir
58
59 # install latest postgresql-client
60 RUN echo 'deb http://apt.postgresql.org/pub/repos/apt/ bullseye-pgdg main' > /etc/apt/
sources.list.d/pgdg.list \
61 && GNUPGHOME="$(mktemp -d)" \
62 && export GNUPGHOME \
63 && repokey='B97B0AFCAA1A47F044F244A07FCC7D46ACCC4CF8' \
```

cicc/Dockerfile.odoo, line 90 (Dockerfile Misconfiguration: Dependency Confusion)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details



Dockerfile Misconfiguration: Dependency Confusion

High

Package: cicd

cicd/Dockerfile.odoo, line 90 (Dockerfile Misconfiguration: Dependency Confusion)

Sink: RUN

File: cicd/Dockerfile.odoo:90

Taint Flags:

```
87 # Fortify Suppress: Dependency Confusion - odoo15.deb is a locally vendored
88 # package (COPY from build context), not fetched from a remote repository.
89 # Version is fixed by the specific .deb file in the cicd/ directory.
90 RUN apt-get update \
91   && apt-get -y install --no-install-recommends /tmp/odoo15.deb \
92   && rm -rf /tmp/* odoo15.deb \
93   && rm -rf /var/lib/apt/lists/*
```

Dockerfile Misconfiguration: Sensitive Host Directory (1 issue)

Abstract

Revealing sensitive host directories might give an attacker access to vital system information

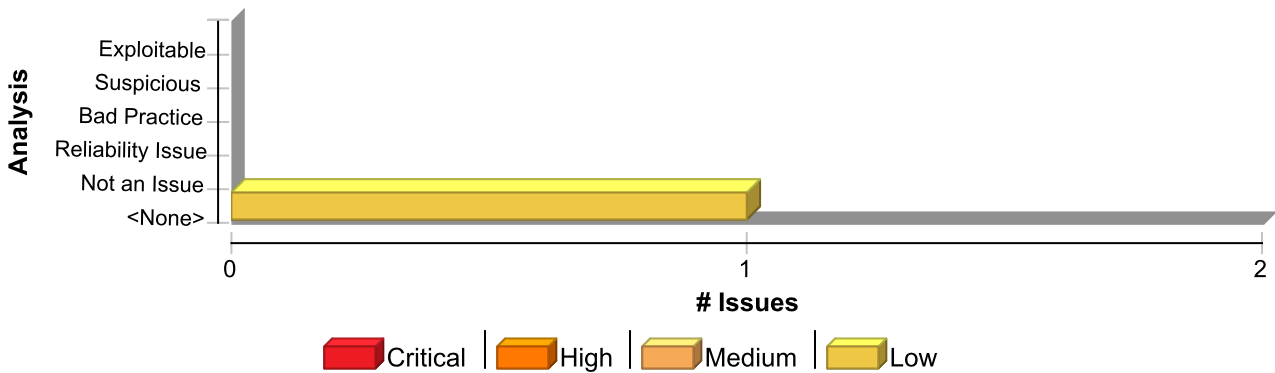
Explanation

You can reconstruct a Dockerfile from a publicly available docker image using docker inspect and the history command, or by automating this process through a third-party tool. If sensitive information is added using the ADD/COPY command, an attacker can recreate each docker layer to obtain the information. Using Vo lumes also can expose sensitive directories. If you need to use Vo lumes to persist data, avoid mounting sensitive directories.

Recommendation

Using the ADD/COPY command, avoid adding any sensitive directories from your host machine. When using Vo lumes, avoid mounting sensitive directories when possible. If it is not possible to avoid use of sensitive directories, make sure to include those directories in read-only mode.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Dockerfile Misconfiguration: Sensitive Host Directory	1	0	0	1
Total	1	0	0	1

Dockerfile Misconfiguration: Sensitive Host Directory

Low

Package: <none>

Dockerfile, line 14 (Dockerfile Misconfiguration: Sensitive Host Directory)

Issue Details

Kingdom: Environment

Scan Engine: SCA (Configuration)

Sink Details



Dockerfile Misconfiguration: Sensitive Host Directory

Low

Package: <none>

Dockerfile, line 14 (Dockerfile Misconfiguration: Sensitive Host Directory)

Sink: COPY

File: Dockerfile:14

Taint Flags:

```
11
12 RUN mkdir -p /app/etc/odoo
13 RUN mkdir -p /app/mnt/extra-addons
14 COPY ./etc/ /app/etc/odoo
15 COPY ./addons /app/mnt/extra-addons
16 RUN echo "$ENV_FILE" > '/app/etc/odoo/.env'
17 RUN echo "$ODOO_CONF" > '/app/etc/odoo/odoo.conf'
```

Hardcoded Domain in HTML (3 issues)

Abstract

Including a script from another domain means that the security of this web page is dependent on the security of the other domain.

Explanation

Including executable content from another web site is a risky proposition. It ties the security of your site to the security of the other site. **Example:** Consider the following script tag.

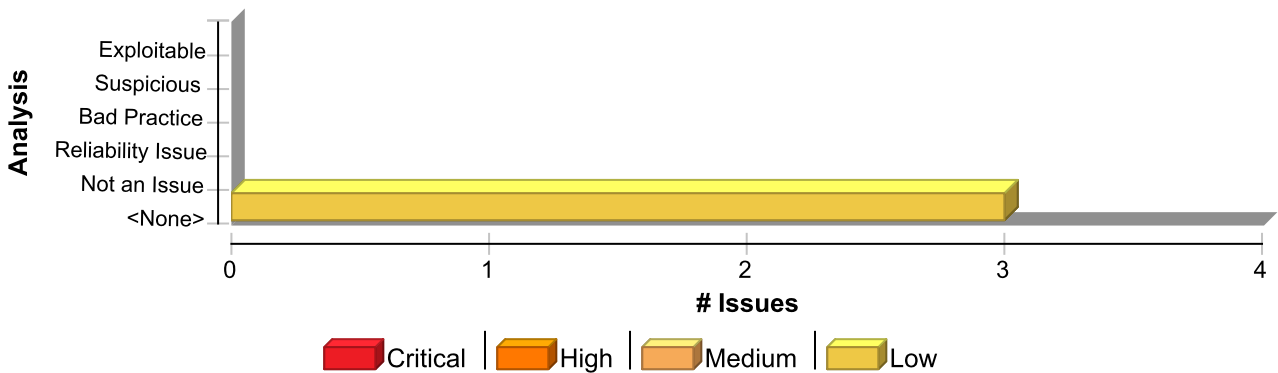
```
<script src="http://www.example.com/js/fancyWidget.js"></script>
```

If this tag appears on a web site other than `www.example.com`, then the site is dependent upon `www.example.com` to serve up correct and non-malicious code. If attackers can compromise `www.example.com`, then they can alter the contents of `fancyWidget.js` to subvert the security of the site. They could, for example, add code to `fancyWidget.js` to steal a user's confidential data.

Recommendation

Keep control over the code your web pages invoke. Do not include scripts or other artifacts from third-party sites.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Hardcoded Domain in HTML	3	0	0	3
Total	3	0	0	3

Hardcoded Domain in HTML

Low

Package: addons.ks_binary_file_preview.static.description

addons/ks_binary_file_preview/static/description/index.html, line 751
(Hardcoded Domain in HTML)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Content)

Sink Details



Hardcoded Domain in HTML

Low

Package: addons.ks_binary_file_preview.static.description

addons/ks_binary_file_preview/static/description/index.html, line 751
(Hardcoded Domain in HTML)

Sink:

File: addons/ks_binary_file_preview/static/description/index.html:751

Taint Flags:

```
748 </div>
749 </div>
750
751 <script src="https://code.jquery.com/jquery-3.3.1.slim.min.js"></script>
752 <script src="https://cdnjs.cloudflare.com/ajax/libs/popper.js/1.14.7/umd/popper.min.js"></script>
753 <script src="https://stackpath.bootstrapcdn.com/bootstrap/4.3.1/js/bootstrap.min.js"></script>
754 </body>
```

addons/ks_binary_file_preview/static/description/index.html, line 752
(Hardcoded Domain in HTML)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Content)

Sink Details

Sink:

File: addons/ks_binary_file_preview/static/description/index.html:752

Taint Flags:

```
749 </div>
750
751 <script src="https://code.jquery.com/jquery-3.3.1.slim.min.js"></script>
752 <script src="https://cdnjs.cloudflare.com/ajax/libs/popper.js/1.14.7/umd/popper.min.js"></script>
753 <script src="https://stackpath.bootstrapcdn.com/bootstrap/4.3.1/js/bootstrap.min.js"></script>
754 </body>
755 </html>
```

addons/ks_binary_file_preview/static/description/index.html, line 753
(Hardcoded Domain in HTML)

Issue Details

Kingdom: Encapsulation

Scan Engine: SCA (Content)

Sink Details

Sink:

File: addons/ks_binary_file_preview/static/description/index.html:753

Taint Flags:



Hardcoded Domain in HTML

Low

Package: addons.ks_binary_file_preview.static.description

addons/ks_binary_file_preview/static/description/index.html, line 753
(Hardcoded Domain in HTML)

750

751 <script src="https://code.jquery.com/jquery-3.3.1.slim.min.js"></script>

752 <script src="https://cdnjs.cloudflare.com/ajax/libs/popper.js/1.14.7/umd/popper.min.js"></script>

753 <script src="https://stackpath.bootstrapcdn.com/bootstrap/4.3.1/js/bootstrap.min.js"></script>

754 </body>

755 </html>

756

Insecure Randomness (5 issues)

Abstract

Standard pseudorandom number generators cannot withstand cryptographic attacks.

Explanation

Insecure randomness errors occur when a function that can produce predictable values is used as a source of randomness in a security-sensitive context. Computers are deterministic machines, and as such are unable to produce true randomness. Pseudorandom Number Generators (PRNGs) approximate randomness algorithmically, starting with a seed from which subsequent values are calculated. There are two types of PRNGs: statistical and cryptographic. Statistical PRNGs provide useful statistical properties, but their output is highly predictable and form an easy to reproduce numeric stream that is unsuitable for use in cases where security depends on generated values being unpredictable. Cryptographic PRNGs address this problem by generating output that is more difficult to predict. For a value to be cryptographically secure, it must be impossible or highly improbable for an attacker to distinguish between the generated random value and a truly random value. In general, if a PRNG algorithm is not advertised as being cryptographically secure, then it is probably a statistical PRNG and should not be used in security-sensitive contexts, where its use can lead to serious vulnerabilities such as easy-to-guess temporary passwords, predictable cryptographic keys, session hijacking, and DNS spoofing. **Example:** The following code uses a statistical PRNG to create a URL for a receipt that remains active for some period of time after a purchase.

```
function genReceiptURL (baseURL){  
  var randNum = Math.random();  
  var receiptURL = baseURL + randNum + ".html";  
  return receiptURL;  
}
```

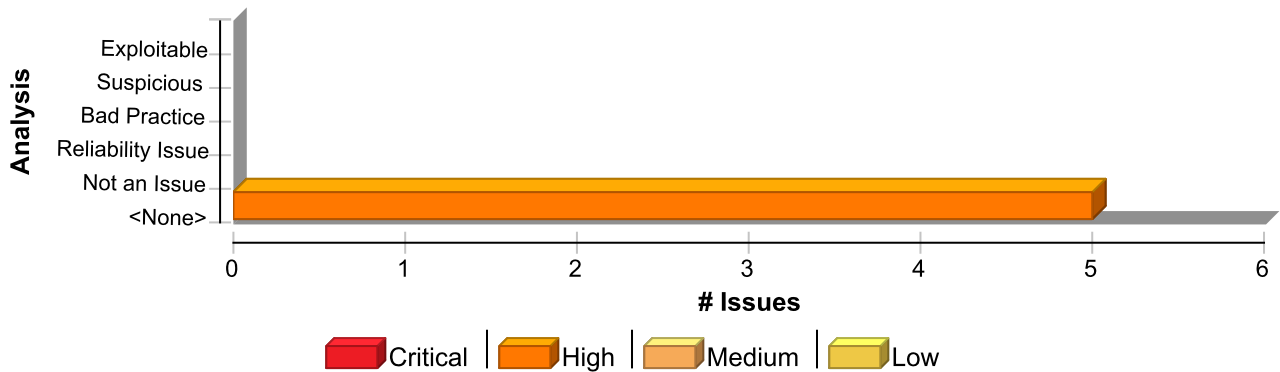
This code uses the `Math.random()` function to generate "unique" identifiers for the receipt pages it generates. Since `Math.random()` is a statistical PRNG, it is easy for an attacker to guess the strings it generates. Although the underlying design of the receipt system is also faulty, it would be more secure if it used a random number generator that did not produce predictable receipt identifiers, such as a cryptographic PRNG.

Recommendation

When unpredictability is critical, as is the case with most security-sensitive uses of randomness, use a cryptographic PRNG. Regardless of the PRNG you choose, always use a value with sufficient entropy to seed the algorithm. (Do not use values such as the current time because it offers only negligible entropy.) In JavaScript, the typical recommendation is to use the `window.crypto.random()` function in the Mozilla API. However, this method does not work in many browsers, including more recent versions of Mozilla Firefox. There is currently no cross-browser solution for a robust cryptographic PRNG. In the meantime, consider handling any PRNG functionality outside of JavaScript.

Issue Summary





Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Insecure Randomness	5	0	0	5
Total	5	0	0	5

Insecure Randomness **High**

Package: .src.js

addons/etc_asset/static/src/js/socket_client.js, line 4008 (Insecure Randomness)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionPointerCall: random
Enclosing Method: duration()
File: addons/etc_asset/static/src/js/socket_client.js:4008
Taint Flags:

```

4005 // Fortify Suppress: Insecure Randomness - Math.random() is used here
4006 // for non-security retry jitter (backoff timer), not for cryptographic
4007 // purposes. No security impact. Third-party library: Socket.IO.
4008 var rand = Math.random();
4009 var deviation = Math.floor(rand * this.jitter * ms);
4010 ms = (Math.floor(rand * 10) & 1) == 0 ? ms - deviation : ms + deviation;
4011 }

```

Package: .src.js.lib

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 12 (Insecure Randomness)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Insecure Randomness

High

Package: .src.js.lib

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 12
(Insecure Randomness)

Sink: FunctionPointerCall: random

Enclosing Method: lambda()

File: addons/etc_project_management_dashboard/static/src/js/lib/loader.js:12

Taint Flags:

```
9 */
10 'use strict';function aa(a){var b=0;return function(){return b<a.length?{done:!1,value:a[b+]}:{done:!0}};var ba="function"===typeof Object.defineProperty?
Object.defineProperty:function(a,b,c){if(a===Array.prototype||a===Object.prototype)return
a;a[b]=c.value;return a};
11 function ca(a){a=["object"===typeof globalThis&&globalThis,a,"object"===typeof
window&&window,"object"===typeof self&&self,"object"===typeof global&&global];for(var
b=0;b<a.length;++b){var c=a[b];if(c&&c.Math===Math)return c}throw Error("Cannot find global
object");}var l=ca(this);function p(a,b){if(b)a:{var c=l;a=a.split(".");for(var
d=0;d<a.length-1;d++){var e=a[d];if(!(e in c))break a;c=c[e]}a=a[a.length-1];d=c[a];b=b!
=d&&null!=b&&ba(c,a,{configurable:!0,writable:!0,value:b})}}
12 p("Symbol",function(a){function b(h){if(this instanceof b)throw new TypeError("Symbol is
not a constructor");return new c(d+(h||"")+ "_" +e++,h)}function c(h,f)
{this.g=h;ba(this,"description",{configurable:!0,writable:!0,value:f})}if(a)return
a;c.prototype.toString=function(){return this.g};var
d="jscomp_symbol_"+(1E9*Math.random()>>>0)+"_",e=0;return b});
13 p("Symbol.iterator",function(a){if(a)return a;a=Symbol("Symbol.iterator");for(var b="Array
Int8Array Uint8Array Uint8ClampedArray Int16Array Uint16Array Int32Array Uint32Array
Float32Array Float64Array".split(" "),c=0;c<b.length;c++){var d=l[b[c]];function e(){return
da(aa(this))}}return a});p("Symbol.asyncIterator",function(a)
{return a?a:Symbol("Symbol.asyncIterator")});
14 function da(a){a={next:a};a[Symbol.iterator]=function(){return this};return a}function q(a)
{var b="undefined"===typeof Symbol&&Symbol.iterator&&a[Symbol.iterator];if(b)return
b.call(a);if("number"===typeof a.length)return{next:aa(a)};throw Error(String(a)+" is not an
iterable or ArrayLike");}function ea(a){if(!(a instanceof Array)){a=q(a);for(var b,c=[];!
(b=a.next()).done;)c.push(b.value);a=c}return a}function r(a,b){return
Object.prototype.hasOwnProperty.call(a,b)}
15 var fa="function"===typeof Object.assign?Object.assign:function(a,b){for(var
c=1;c<arguments.length;c++){var d=arguments[c];if(d)for(var e in d)r(d,e)&&(a[e]=d[e])}return
a};p("Object.assign",function(a){return a||fa});var ha;if("function"===typeof
Object.setPrototypeOf)ha=Object.setPrototypeOf;else{var ia;a:{var ja={a:!
0},ka={};try{ka.__proto__=ja;ia=ka.a;break a}catch(a){}ia=!1}ha=ia?function(a,b)
{a.__proto__=b;if(a.__proto__!=b)throw new TypeError(a+" is not extensible");return a}:null}
var t=ha;
```

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 25
(Insecure Randomness)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionPointerCall: random

Enclosing Method: lambda()

File: addons/etc_project_management_dashboard/static/src/js/lib/loader.js:25

Taint Flags:



Insecure Randomness

High

Package: .src.js.lib

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 25
(Insecure Randomness)

```
22 m.g);}}var m=this;null==this.h?h.h(k):this.h.push(k);this.o=!
0;b.resolve=d;b.reject=function(f){return new b(function(g,k){k(f)}};b.race=function(f)
{return new b(function(g,k){for(var m=q(f),n=m.next();!
n.done;n=m.next())d(n.value).F(g,k)}};b.all=function(f){var g=q(f),k=g.next();return k.done?
d([]):new b(function(m,n){function u(ra){return function(sa){y[ra]=sa;G--;0==G&&m(y)}}var
y=[],G=0;do y.push(void 0),G++,d(k.value).F(u(y.length-1),n),k=g.next();while(!
k.done)}};return b));
23 p("Object.setPrototypeOf",function(a){return a||t});
24 p("WeakMap",function(a){function b(k){this.g=(g+=Math.random()+1).toString();if(k)
{k=q(k);for(var m;! (m=k.next()).done;)m=m.value,this.set(m[0],m[1])}}function c(){}function
d(k){var m=typeof k;return"object"===m&&null!==k||"function"===m}function e(k){if(!r(k,f)){var
m=new c;ba(k,f,{value:m})}function h(k){var m=Object[k];m&&(Object[k]=function(n){if(n
instanceof c)return n;Object.isExtensible(n)&&e(n);return m(n)})}if(function(){if(!a||!
Object.seal)return!1;try{var k=Object.seal({}),m=Object.seal({}),
25 n=new a([[k,2],[m,3]]);if(2!=n.get(k)||3!=n.get(m))return!1;n.delete(k);n.set(m,4);return!
n.has(k)&&4==n.get(m)}catch(u){return!1}}())return a;var
f="$jscomp_hidden_"+Math.random();h("freeze");h("preventExtensions");h("seal");var
g=0;b.prototype.set=function(k,m){if(!d(k))throw Error("Invalid WeakMap key");e(k);if(!
r(k,f))throw Error("WeakMap key fail: "+k);k[f][this.g]=m;return
this;b.prototype.get=function(k){return d(k)&&r(k,f)?k[f][this.g]:void
0;b.prototype.has=function(k){return d(k)&&r(k,
26 f)&&r(k[f],this.g)};b.prototype.delete=function(k){return d(k)&&r(k,f)&&r(k[f],this.g)?
delete k[f][this.g]:!1};return b});
27 p("Map",function(a){function b(){var g={};return g.v=g.next=g.head=g}function c(g,k){var
m=g.g;return da(function(){if(m){for(;m.head!=g.g;)m=m.v;for(;m.next!=m.head;)return m=m.next,
{done:!1,value:k(m)};m=null}return{done:!0,value:void 0}})}function d(g,k){var m=k&&typeof
k;"object"===m||"function"===m?h.has(k)?m=h.get(k):(m=""+ ++f,h.set(k,m)):m="p_"+k;var
n=g.h[m];if(n&&r(g.h,m))for(g=0;g<n.length;g++){var u=n[g];if(k!==k&&u.key!==u.key||
k===u.key)return{id:m,list:n,index:g,s:u}}return{id:m,list:n,
28 index:-1,s:void 0}}function e(g){this.h={};this.g=b();this.size=0;if(g){g=q(g);for(var k;!
(k=g.next()).done;)k=k.value,this.set(k[0],k[1])}if(function(){if(!a||"function"!==typeof a||!
a.prototype.entries||"function"!==typeof Object.seal)return!1;try{var
g=Object.seal({x:4}),k=new a(q([[g,"s"]]]);if("s"!=k.get(g)||1!=k.size||k.get({x:4})||
k.set({x:4},"t")!=k||2!=k.size)return!1;var m=k.entries(),n=m.next();if(n.done||n.value[0]!
=g||"s"!=n.value[1])return!1;n=m.next();return n.done||4!=n.value[0].x||
```

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 24
(Insecure Randomness)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionPointerCall: random
Enclosing Method: b()
File: addons/etc_project_management_dashboard/static/src/js/lib/loader.js:24
Taint Flags:



Insecure Randomness

High

Package: .src.js.lib

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 24
(Insecure Randomness)

```
21 function(f){var g=this.j();f.F(g.resolve,g.reject)};b.prototype.P=function(f,g){var
k=this.j();try{f.call(g,k.resolve,k.reject)}catch(m)
{k.reject(m)}};b.prototype.then=function(f,g){function k(y,G){return"function"==typeof y?
function(ra){try{m(y(ra))}catch(sa){n(sa)}}:G}var m,n,u=new b(function(y,G)
{m=y;n=G});this.F(k(f,m),k(g,n));return u};b.prototype.catch=function(f){return this.then(void
0,f)};b.prototype.F=function(f,g){function k(){switch(m.g){case 1:f(m.i);break;case
2:g(m.i);break;default:throw Error("Unexpected state: "+
22 m.g)};}}var m=this;null==this.h?h.h(k):this.h.push(k);this.o=!
0};b.resolve=d;b.reject=function(f){return new b(function(g,k){k(f)}}};b.race=function(f)
{return new b(function(g,k){for(var m=q(f),n=m.next();!
n.done;n=m.next())d(n.value).F(g,k)}});b.all=function(f){var g=q(f),k=g.next();return k.done?
d([]):new b(function(m,n){function u(ra){return function(sa){y[ra]=sa;G--;0==G&&m(y)}}var
y=[],G=0;do y.push(void 0),G++,d(k.value).F(u(y.length-1),n),k=g.next();while(!
k.done)});return b});
23 p("Object.setPrototypeOf",function(a){return a||t});
24 p("WeakMap",function(a){function b(k){this.g=(g+=Math.random()+1).toString();if(k)
{k=q(k);for(var m;! (m=k.next()).done;)m=m.value,this.set(m[0],m[1])}}function
d(k){var m=typeof k;return"object"===m&&null!==k||"function"===m}function e(k){if(!r(k,f)){var
m=new c;ba(k,f,{value:m})}}function h(k){var m=Object[k];m&&(Object[k]=function(n){if(n
instanceof c)return n;Object.isExtensible(n)&&e(n);return m(n)})}if(function(){if(!a||!
Object.seal)return!1;try{var k=Object.seal({}),m=Object.seal({}),
25 n=new a([[k,2],[m,3]]);if(2!=n.get(k)||3!=n.get(m))return!1;n.delete(k);n.set(m,4);return!
n.has(k)&&4==n.get(m)}catch(u){return!1}}())return a;var
f="$jscomp_hidden_"+Math.random();h("freeze");h("preventExtensions");h("seal");var
g=0;b.prototype.set=function(k,m){if(!d(k))throw Error("Invalid WeakMap key");e(k);if(!
r(k,f))throw Error("WeakMap key fail: "+k);k[f][this.g]=m;return
this};b.prototype.get=function(k){return d(k)&&r(k,f)?k[f][this.g]:void
0};b.prototype.has=function(k){return d(k)&&r(k,
26 f)&&r(k[f],this.g)};b.prototype.delete=function(k){return d(k)&&r(k,f)&&r(k[f],this.g)?
delete k[f][this.g]:!1};return b});
27 p("Map",function(a){function b(){var g={};return g.v=g.next=g.head=g}function c(g,k){var
m=g.g;return da(function(){if(m){for(;m.head!=g.g;)m=m.v;for(;m.next!=m.head;)return m=m.next,
{done:!1,value:k(m)};m=null}return{done:!0,value:void 0}})}function d(g,k){var m=k&&typeof
k;"object"===m||"function"===m?h.has(k)?m=h.get(k):(m=""++f,h.set(k,m)):m="p_"+k;var
n=g.h[m];if(n&&r(g.h,m))for(g=0;g<n.length;g++){var u=n[g];if(k!==k&&u.key!==u.key||
k===u.key)return{id:m,list:n,index:g,s:u}}return{id:m,list:n,
```

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 110
(Insecure Randomness)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: FunctionPointerCall: random
Enclosing Method: a()
File: addons/etc_project_management_dashboard/static/src/js/lib/loader.js:110
Taint Flags:



addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 110
(Insecure Randomness)

```

107 N.prototype.get=function(a,b){if(!a)return b;a=sb(this,a);return 0<a.length?
String(a[0]):b};N.prototype.toString=function(){if(this.i)return this.i;if(!
this.g)return"";for(var a=[],b=Array.from(this.g.keys()),c=0;c<b.length;c++){var
d=b[c],e=encodeURIComponent(String(d));d=sb(this,d);for(var h=0;h<d.length;h++){var f=e;""!
==d[h]&&(f+="="+encodeURIComponent(String(d[h])));a.push(f)}}return
this.i=a.join("&");function ib(a){var b=new N;b.i=a.i;a.g&&(b.g=new Map(a.g),b.h=a.h);return
b}

108 function Q(a,b){b=String(b);a.j&&(b=b.toLowerCase());return b}function nb(a,b){b&&!
a.j&&(P(a),a.i=null,a.g.forEach(function(c,d){var e=d.toLowerCase();if(d!
=e&&(qb(this,d),qb(this,e),0<c.length)){this.i=null;d=this.g;var h=d.set;e=Q(this,e);var
f=c.length;if(0<f){for(var g=Array(f),k=0;k<f;k++)g[k]=c[k];f=g}else
f=[];h.call(d,e,f);this.h+=c.length}},a));a.j=b};function tb(a,b){Ua(b,function(c,d)
{c&&"object"===typeof c&&c.K&&(c=c.I());"style"===d?a.style.cssText=c:"class"===d?
a.className=c:"for"===d?a.htmlFor=c:ub.hasOwnProperty(d)?
a.setAttribute(ub[d],c):0==d.lastIndexOf("aria-",0)||0==d.lastIndexOf("data-",0)?
a.setAttribute(d,c):a[d]=c)}}

109 var
ub={cellpadding:"cellPadding",cellspacing:"cellSpacing",colspan:"colSpan",frameborder:"frameBord
vb(a,b){b=String(b);"application/xhtml+xml"===a.contentType&&(b=b.toLowerCase());return
a.createElement(b)}function wb(a){this.g=a|A.document|document};function xb(){};function
yb(a,b){this.i=a;this.j=b;this.h=0;this.g=null}yb.prototype.get=function(){if(0<this.h)
{this.h--;var a=this.g;this.g=a.next;a.next=null}else a=this.i();return a};function zb(a,b)
{a.j(b);100>a.h&&(a.h++,b.next=a.g,a.g=b)};var Ab;

110 function Bb(){var a=A.MessageChannel;"undefined"===typeof a&&"undefined"!==typeof
window&&window.postMessage&&window.addEventListener&&-1==a().indexOf("Presto")&&(a=function()
{var
e=vb(document,"IFRAME");e.style.display="none";document.documentElement.appendChild(e);var
h=e.contentWindow;e=h.document;e.open();e.close();var
f="callImmediate"+Math.random(),g="file:"===h.location.protocol?"*":h.location.protocol+"//"+h.lo
c
if(("*"===g||k.origin===g)&&k.data===f)this.port1.onmessage(),this);

111 h.addEventListener("message",e,!1);this.port1={};this.port2={postMessage:function()
{h.postMessage(f,g)}});if("undefined"!==typeof
a&&(Xa&&K&&0<K.brands.length||-1==a().indexOf("Trident")&&-1==a().indexOf("MSIE"))){var
b=new a,c={},d=c;b.port1.onmessage=function(){if(void 0!==c.next){c=c.next;var
e=c.H;c.H=null;e()}};return function(e){d.next={H:e};d=d.next;b.port2.postMessage(0)}return
function(e){A.setTimeout(e,0)};function Cb(a){A.setTimeout(function(){throw a;},0)};function
Db(){this.h=this.g=null}Db.prototype.add=function(a,b){var c=Eb.get();c.set(a,b);this.h?
this.h.next=c:this.g=c;this.h=c};function Fb(){var a=Gb,b=null;a.g&&(b=a.g,a.g=a.g.next,a.g||
a.h=null),b.next=null;return b}var Eb=new yb(function(){return new Hb},function(a){return
a.reset()});function Hb(){this.next=this.g=this.h=null}Hb.prototype.set=function(a,b)
{this.h=a;this.g=b;this.next=null};Hb.prototype.reset=function()
{this.next=this.g=this.h=null};var Ib,Jb=!1,Gb=new Db;function Kb(a,b){Ib||Lb();Jb||
(Ib(),Jb=!0);Gb.add(a,b)}function Lb(){if(A.Promise&&A.Promise.resolve){var a=A.Promise.resolve(void
0);Ib=function(){a.then(Mb)}}else Ib=function(){var b=Mb;"function"!==typeof A.setImmediate||
A.Window&&A.Window.prototype&&(Xa&&K&&0<K.brands.length||-1==a().indexOf("Edge"))&&A.Window.pro
(Ab||
(Ab=Bb()),Ab(b)):A.setImmediate(b)}}

112 function Mb(){for(var a;a=Fb());{try{a.h.call(a.g)}catch(b){Cb(b)}zb(Eb,a)}Jb=!1};function
Nb(a){if(!a)return!1;try{return!a.$goog_Thenable}catch(b){return!1}};function R(a)
{this.g=0;this.o=void 0;this.j=this.h=this.i=null;this.l=this.m=!1;if(a!=Ta)try{var
b=this;a.call(void 0,function(c){S(b,2,c)},function(c){S(b,3,c)})}catch(c){S(this,3,c)}}
function Ob(){this.next=this.i=this.h=this.j=this.g=null;this.l=!1}
Ob.prototype.reset=function(){this.i=this.h=this.j=this.g=null;this.l=!1};var Pb=new
yb(function(){return new Ob},function(a){a.reset()});function Qb(a,b,c){var
d=Pb.get();d.j=a;d.h=b;d.i=c;return d}

113 R.prototype.then=function(a,b,c){return Rb(this,"function"===typeof a?
a:null,"function"===typeof b?b:null,c)};R.prototype.$goog_Thenable=!
0;R.prototype.cancel=function(a){if(0==this.g){var b=new T(a);Kb(function()

```

Insecure Randomness

High

Package: .src.js.lib

addons/etc_project_management_dashboard/static/src/js/lib/loader.js, line 110
(Insecure Randomness)

```
{Sb(this,b)},this)}};function Sb(a,b){if(0==a.g)if(a.i){var c=a.i;if(c.h){for(var d=0,e=null,h=null,f=c.h;f&&(f.l||(d++,f.g==a&&(e=f),!(e&&1<d)));f=f.next)e||(h=f);e&&(0==c.g&&1==d?Sb(c,b):(h?(d=h,d.next==c.j&&(c.j=d),d.next=d.next.next):Tb(c),Ub(c,e,3,b)))}a.i=null}else S(a,3,b)}
```


Password Management: Empty Password (1 issue)

Abstract

Empty passwords can compromise system security in a way that cannot be easily remedied.

Explanation

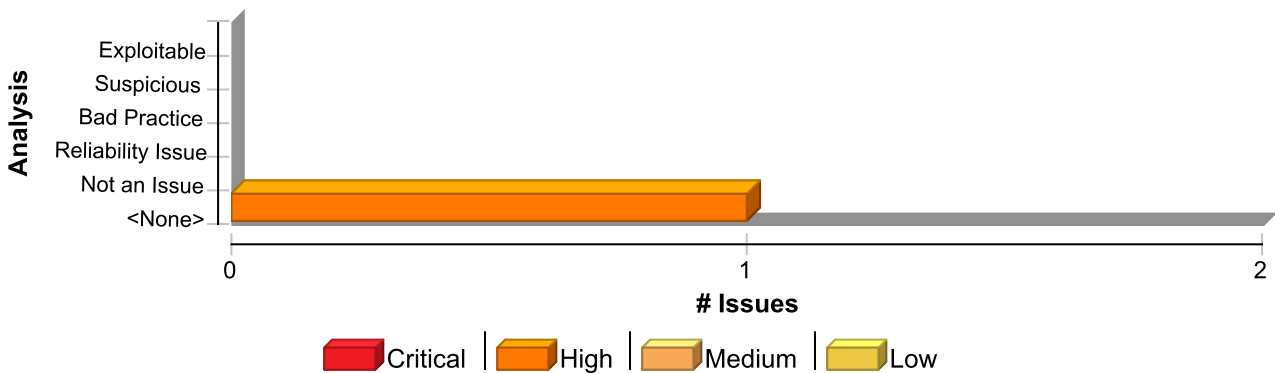
Never assign an empty string to a password variable. If the empty password is successfully used to authenticate against a system, then the corresponding account's security is likely compromised because it accepts an empty password. **Example:** The following JSON initializes an empty password.

```
{
  ...
  "password" : ""
  ...
}
```

Recommendation

Require that sufficiently hard-to-guess passwords protect all accounts and system resources. Consult the references to help establish appropriate password guidelines.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Password Management: Empty Password	1	0	0	1
Total	1	0	0	1

Password Management: Empty Password

High

Package: addons.auth_oidc.tests.keycloak

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 398 (Password Management: Empty Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)



Password Management: Empty Password

High

Package: addons.auth_oidc.tests.keycloak

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 398 (Password Management: Empty Password)

Sink Details

Sink: ConfigPair

File: addons/auth_oidc/tests/keycloak/keycloak-config.json:398

Taint Flags:

```
395 "webAuthnPolicyAcceptableAaguids": [],
396 "webAuthnPolicyPasswordlessRpEntityName": "keycloak",
397 "webAuthnPolicyPasswordlessSignatureAlgorithms": ["ES256"],
398 "webAuthnPolicyPasswordlessRpId": "",
399 "webAuthnPolicyPasswordlessAttestationConveyancePreference": "not specified",
400 "webAuthnPolicyPasswordlessAuthenticatorAttachment": "not specified",
401 "webAuthnPolicyPasswordlessRequireResidentKey": "not specified",
```



Password Management: Hardcoded Password (5 issues)

Abstract

Hardcoded passwords can compromise system security in a way that is difficult to remedy.

Explanation

Never hardcode passwords. Not only does it expose the password to all of the project's developers, it also makes fixing the problem extremely difficult. After the code is in production, a program patch is probably the only way to change the password. If the account the password protects is compromised, the system owners must choose between security and availability. **Example:** The following JSON uses a hardcoded password:

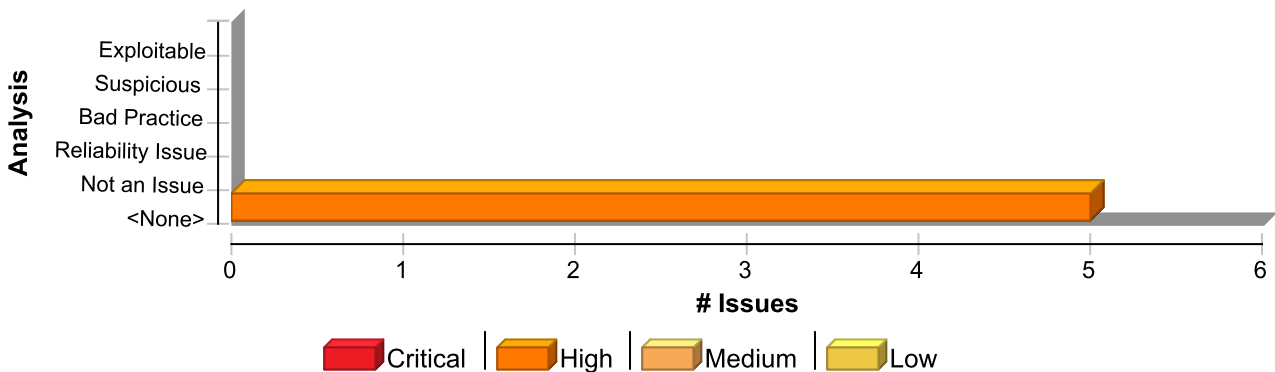
```
...
{
  "username":"scott"
  "password":"tiger"
}
...
```

This configuration may be valid, but anyone who has access to the configuration will have access to the password. After the program is released, changing the default user account "scott" with a password of "tiger" is difficult. Anyone with access to this information can use it to break into the system.

Recommendation

Never hardcode password. Passwords should generally be obfuscated and managed in an external source. Storing passwords in plain text anywhere on the system allows anyone with sufficient permissions to read and potentially misuse the password.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Password Management: Hardcoded Password	5	0	0	5
Total	5	0	0	5



Password Management: Hardcoded Password

High

Package: addons.auth_oidc.tests.keycloak

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 396 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: ConfigPair
File: addons/auth_oidc/tests/keycloak/keycloak-config.json:396
Taint Flags:

```
393 "webAuthnPolicyCreateTimeout": 0,  
394 "webAuthnPolicyAvoidSameAuthenticatorRegister": false,  
395 "webAuthnPolicyAcceptableAaguids": [],  
396 "webAuthnPolicyPasswordlessRpEntityName": "keycloak",  
397 "webAuthnPolicyPasswordlessSignatureAlgorithms": ["ES256"],  
398 "webAuthnPolicyPasswordlessRpId": "",  
399 "webAuthnPolicyPasswordlessAttestationConveyancePreference": "not specified",
```

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 399 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: ConfigPair
File: addons/auth_oidc/tests/keycloak/keycloak-config.json:399
Taint Flags:

```
396 "webAuthnPolicyPasswordlessRpEntityName": "keycloak",  
397 "webAuthnPolicyPasswordlessSignatureAlgorithms": ["ES256"],  
398 "webAuthnPolicyPasswordlessRpId": "",  
399 "webAuthnPolicyPasswordlessAttestationConveyancePreference": "not specified",  
400 "webAuthnPolicyPasswordlessAuthenticatorAttachment": "not specified",  
401 "webAuthnPolicyPasswordlessRequireResidentKey": "not specified",  
402 "webAuthnPolicyPasswordlessUserVerificationRequirement": "not specified",
```

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 400 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details



Password Management: Hardcoded Password

High

Package: addons.auth_oidc.tests.keycloak

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 400 (Password Management: Hardcoded Password)

Sink: ConfigPair

File: addons/auth_oidc/tests/keycloak/keycloak-config.json:400

Taint Flags:

```
397 "webAuthnPolicyPasswordlessSignatureAlgorithms": ["ES256"],
398 "webAuthnPolicyPasswordlessRpId": "",
399 "webAuthnPolicyPasswordlessAttestationConveyancePreference": "not specified",
400 "webAuthnPolicyPasswordlessAuthenticatorAttachment": "not specified",
401 "webAuthnPolicyPasswordlessRequireResidentKey": "not specified",
402 "webAuthnPolicyPasswordlessUserVerificationRequirement": "not specified",
403 "webAuthnPolicyPasswordlessCreateTimeout": 0,
```

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 401 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: ConfigPair

File: addons/auth_oidc/tests/keycloak/keycloak-config.json:401

Taint Flags:

```
398 "webAuthnPolicyPasswordlessRpId": "",
399 "webAuthnPolicyPasswordlessAttestationConveyancePreference": "not specified",
400 "webAuthnPolicyPasswordlessAuthenticatorAttachment": "not specified",
401 "webAuthnPolicyPasswordlessRequireResidentKey": "not specified",
402 "webAuthnPolicyPasswordlessUserVerificationRequirement": "not specified",
403 "webAuthnPolicyPasswordlessCreateTimeout": 0,
404 "webAuthnPolicyPasswordlessAvoidSameAuthenticatorRegister": false,
```

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 402 (Password Management: Hardcoded Password)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: ConfigPair

File: addons/auth_oidc/tests/keycloak/keycloak-config.json:402

Taint Flags:



Password Management: Hardcoded Password

High

Package: addons.auth_oidc.tests.keycloak

addons/auth_oidc/tests/keycloak/keycloak-config.json, line 402 (Password Management: Hardcoded Password)

```
399 "webAuthnPolicyPasswordlessAttestationConveyancePreference": "not specified",
400 "webAuthnPolicyPasswordlessAuthenticatorAttachment": "not specified",
401 "webAuthnPolicyPasswordlessRequireResidentKey": "not specified",
402 "webAuthnPolicyPasswordlessUserVerificationRequirement": "not specified",
403 "webAuthnPolicyPasswordlessCreateTimeout": 0,
404 "webAuthnPolicyPasswordlessAvoidSameAuthenticatorRegister": false,
405 "webAuthnPolicyPasswordlessAcceptableAaguids": [],
```

Password Management: Password in Comment (9 issues)

Abstract

Storing passwords or password details in plain text anywhere in the system or system code might compromise system security in a way that cannot be easily remedied.

Explanation

It is never a good idea to hardcode a password. Storing password details within comments is equivalent to hardcoding passwords. Not only is the password visible to the project's developers, it also makes fixing the problem extremely difficult. After the code is in production, the password is now leaked to the outside world and cannot be protected or changed without patching the software. If the account protected by the password is compromised, the owners of the system must choose between security and availability.

Example: The following comment specifies the default password to connect to a database:

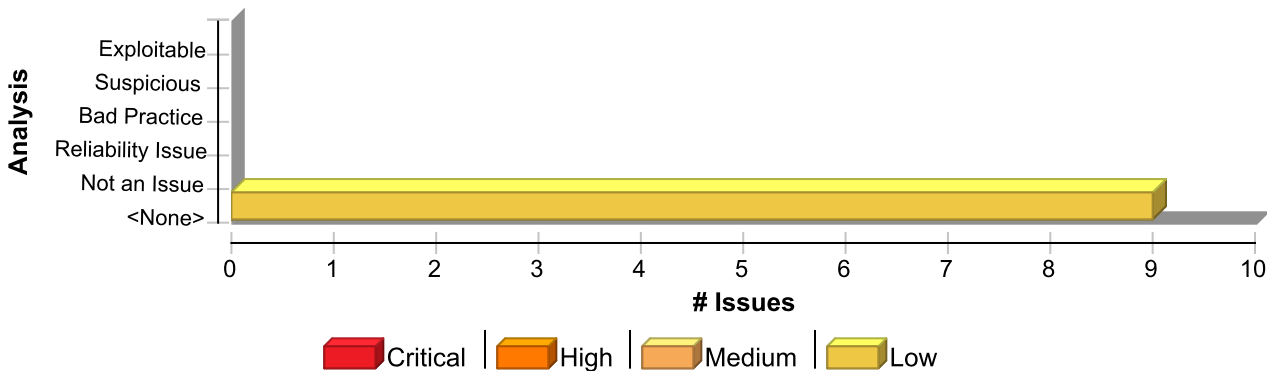
```
...
# Default username for database connection is "scott"
# Default password for database connection is "tiger"
...
```

This code will run successfully, but anyone who has access to it will have access to the password. An employee with access to this information can use it to break into the system.

Recommendation

Passwords should never be hardcoded and should generally be obfuscated and managed in an external source. Storing passwords in plain text anywhere on the system allows anyone with sufficient permissions to read and potentially misuse the password.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Password Management: Password in Comment	9	0	0	9
Total	9	0	0	9



Password Management: Password in Comment

Low

Package: addons.auth_ldap_custom.views

addons/auth_ldap_custom/views/templates.xml, line 24 (Password Management: Password in Comment)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Configuration)

Sink Details

Sink:
File: addons/auth_ldap_custom/views/templates.xml:24
Taint Flags:

```
21 <option type="radio" value="etc">etc.vn</option>
22 <option type="radio" value="epay">epayjsc.com</option>
23 </select>
24 </xpath> -->
25 </template>
26
27 <template id="auth_signup_login_layout_etc" name="Layout" inherit_id="web.login_layout">
```

Package: addons.etc_api.models

addons/etc_api/models/res_users.py, line 54 (Password Management: Password in Comment)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)

Sink Details

Sink: Comment
File: addons/etc_api/models/res_users.py:54
Taint Flags:

```
51 # except AccessDenied:
52 # # verify password as token
53 # if not validator.verify(password):
54 # raise
55
56 class MyEmployeeETC(models.Model):
57     _inherit = "hr.employee"
```

Package: addons.etc_api.tools

addons/etc_api/tools/crypto.py, line 20 (Password Management: Password in Comment)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Structural)



Password Management: Password in Comment

Low

Package: addons.etc_api.tools

addons/etc_api/tools/crypto.py, line 20 (Password Management: Password in Comment)

Sink Details

Sink: Comment

File: addons/etc_api/tools/crypto.py:20

Taint Flags:

```
17 # derive encryption key: 32 byte key length
18 # in assumption the masterkey is a cryptographic and NOT a password there is no need for
19 # a large number of iterations. It may can replaced by HKDF
20 # the value of 2145 is randomly
21 key = PBKDF2(password, salt, dkLen=32, count=65536, hmac_hash_module=SHA256)
22 # AES 256 GCM Mode
23 cipher = AES.new(key, AES.MODE_GCM)
```

Package: addons.etc_cron_create_account_employee.models

addons/etc_cron_create_account_employee/models/
etc_create_account_employee.py, line 96 (Password Management: Password in Comment)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: Comment

File: addons/etc_cron_create_account_employee/models/etc_create_account_employee.py:96

Taint Flags:

```
93 # enable user (after password set)
94
95 conn.modify(currentUser, {'userPassword': [(MODIFY_REPLACE, [defaultPass])]])
96 # conn.modify(currentUser, {'pwdLastSet': [(MODIFY_REPLACE, 0)])} #User must change
password at next logon
97 conn.modify(currentUser, {'userAccountControl': [(MODIFY_REPLACE, 512)])}
98 # conn.modify(currentUser, {'lockoutTime': [(MODIFY_REPLACE, 0)])}
99 # addUsersInGroups(conn, currentUser, user_ou)
```

addons/etc_cron_create_account_employee/models/
etc_create_account_employee.py, line 122 (Password Management: Password in Comment)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details



Password Management: Password in Comment

Low

Package: addons.etc_cron_create_account_employee.models

addons/etc_cron_create_account_employee/models/
etc_create_account_employee.py, line 122 (Password Management: Password in
Comment)

Sink: Comment

File: addons/etc_cron_create_account_employee/models/etc_create_account_employee.py:122

Taint Flags:

```
119 # # enable user (after password set)
120 # conn.modify(currentUser, {'userAccountControl': [('MODIFY_REPLACE', 512)]})
121 # # disable user
122 # conn.modify(currentUser, {'userAccountControl': [('MODIFY_REPLACE', 2)]})
123
124 except Exception as e:
125 print('Create Account AD error', e)
```

addons/etc_cron_create_account_employee/models/
etc_create_account_employee.py, line 93 (Password Management: Password in
Comment)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: Comment

File: addons/etc_cron_create_account_employee/models/etc_create_account_employee.py:93

Taint Flags:

```
90 # {'userPassword': [(MODIFY_REPLACE, [defaultPass])],
91 # 'userAccountControl': [(MODIFY_REPLACE, [512])])}
92 # conn.extend.microsoft.modify_password(user=currentUser, new_password='Etc@1234',
old_password=None)
93 # enable user (after password set)
94
95 conn.modify(currentUser, {'userPassword': [(MODIFY_REPLACE, [defaultPass])])})
96 # conn.modify(currentUser, {'pwdLastSet': [(MODIFY_REPLACE, 0)]}) #User must change
password at next logon
```

Package: addons.oh_hr_zk_attendance.models

addons/oh_hr_zk_attendance/models/zklib.py, line 138 (Password Management:
Password in Comment)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details



Password Management: Password in Comment

Low

Package: addons.oh_hr_zk_attendance.models

addons/oh_hr_zk_attendance/models/zklib.py, line 138 (Password Management: Password in Comment)

Sink: Comment

File: addons/oh_hr_zk_attendance/models/zklib.py:138

Taint Flags:

```
135
136 def setUser(self, uid, userid, name, password, role):
137 # Fortify Suppress: Privacy Violation - password passed to zksetuser which
138 # requires plaintext per ZK device protocol. See zkuser.py for full justification.
139 return zksetuser(self, uid, userid, name, password, role)
140
141 def clearUser(self):
```

addons/oh_hr_zk_attendance/models/zkuser.py, line 29 (Password Management: Password in Comment)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: Comment

File: addons/oh_hr_zk_attendance/models/zkuser.py:29

Taint Flags:

```
26 # plaintext password in CMD_SET_USER binary payload. This is a hardware/firmware
27 # constraint from the device vendor (ZKTeco). Cannot hash without breaking device
28 # authentication. Compensating controls: device on isolated VLAN, firewall ACL
29 # restricts traffic to Odoo server <-> ZK device only.
30 command_string = pack('sxs8s28ss7sx8s16s', chr( uid ), chr(role), password, name, chr(1),
31 '', userid, '' )
31 chksum = 0
32 session_id = self.session_id
```

Package: addons.queue_job.jobrunner

addons/queue_job/jobrunner/runner.py, line 4 (Password Management: Password in Comment)

Issue Details

Kingdom: Security Features

Scan Engine: SCA (Structural)

Sink Details

Sink: Comment

File: addons/queue_job/jobrunner/runner.py:4

Taint Flags:



Password Management: Password in Comment

Low

Package: addons.queue_job.jobrunner

addons/queue_job/jobrunner/runner.py, line 4 (Password Management: Password in Comment)

```
1 # Copyright (c) 2015-2016 ACSONE SA/NV (<http://acsone.eu>)
2 # Copyright 2015-2016 Camptocamp SA
3 # License LGPL-3.0 or later (http://www.gnu.org/licenses/lgpl.html)
4 """
5 What is the job runner?
6 -----
7 The job runner is the main process managing the dispatch of delayed jobs to
```

Path Manipulation (1 issue)

Abstract

Allowing user input to control paths used in file system operations could enable an attacker to access or modify otherwise protected system resources.

Explanation

Path manipulation errors occur when the following two conditions are met: 1. An attacker can specify a path used in an operation on the file system. 2. By specifying the resource, the attacker gains a capability that would not otherwise be permitted. For example, the program might give the attacker the ability to overwrite the specified file or run with a configuration controlled by the attacker. **Example 1:** The following code uses input from an HTTP request to create a file name. The programmer has not considered the possibility that an attacker could provide a file name such as `../../../../tomcat/conf/server.xml`, which causes the application to delete one of its own configuration files.

```
rName = req.field('reportName')
rFile = os.open("/usr/local/apfr/reports/" + rName)
...
os.unlink(rFile);
```

Example 2: The following code uses input from a configuration file to determine which file to open and echo back to the user. If the program runs with adequate privileges and malicious users can change the configuration file, they can use the program to read any file on the system that ends with the extension `.txt`.

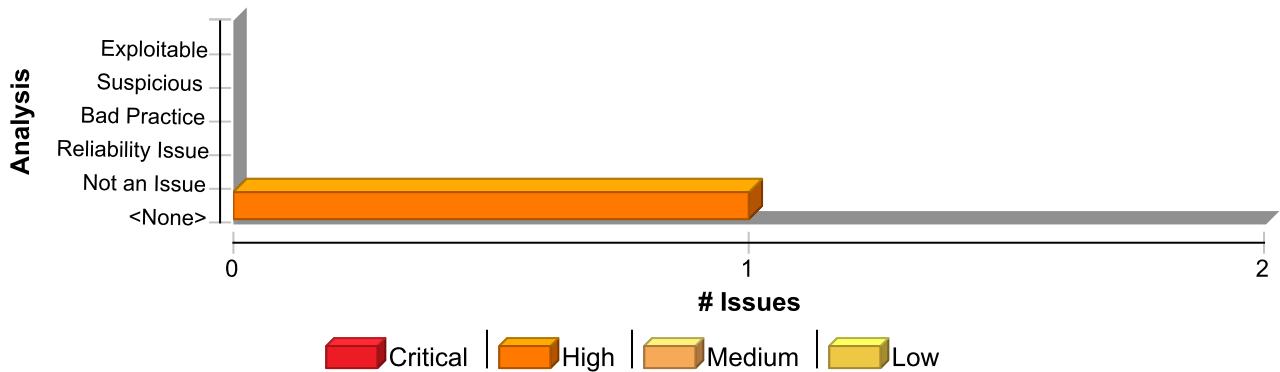
```
...
filename = CONFIG_TXT['sub'] + ".txt";
handle = os.open(filename)
print handle
...
```

Recommendation

The best way to prevent path manipulation is with a level of indirection: create a list of legitimate values from which the user must select. With this approach, the user-provided input is never used directly to specify the resource name. In some situations this approach is impractical because the set of legitimate resource names is too large or too hard to maintain. Programmers often resort to implementing a deny list in these situations. A deny list is used to selectively reject or escape potentially dangerous characters before using the input. However, any such list of unsafe characters is likely to be incomplete and will almost certainly become out of date. A better approach is to create a list of characters that are permitted to appear in the resource name and accept input composed exclusively of characters in the approved set.

Issue Summary





Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Path Manipulation	1	0	0	1
Total	1	0	0	1

Path Manipulation

High

Package: addons.auto_backup.models.db_backup

addons/auto_backup/models/db_backup.py, line 312 (Path Manipulation)

Issue Details

Kingdom: Input Validation and Representation
Scan Engine: SCA (Data Flow)

Source Details

Source: open()
From: addons.auto_backup.models.db_backup.DbBackup.schedule_backup
File: addons/auto_backup/models/db_backup.py:130

```
127 # using os.path.realpath() + startswith() check to prevent path
traversal.
128 try:
129 # try to backup database and write it away
130 fp = open(file_path, 'wb')
131 self._take_dump(rec.name, fp, 'db.backup', rec.backup_type)
132 fp.close()
133 except Exception as error:
```

Sink Details

Sink: shutil.copyfileobj()
Enclosing Method: _take_dump()
File: addons/auto_backup/models/db_backup.py:312
Taint Flags: FILE_SYSTEM



Path Manipulation

High

Package: addons.auto_backup.models.db_backup

addons/auto_backup/models/db_backup.py, line 312 (Path Manipulation)

```
309 if stream:
310     # Fortify Suppress: Path Manipulation - stream is a validated
311     # file handle from schedule_backup (path checked at open()).
312     shutil.copyfileobj(stdout, stream)
313 else:
314     return stdout
315
```

Poor Error Handling: Empty Catch Block (13 issues)

Abstract

Ignoring an exception can cause the program to overlook unexpected states and conditions.

Explanation

Just about every serious attack on a software system begins with the violation of a programmer's assumptions. After the attack, the programmer's assumptions seem flimsy and poorly founded, but before an attack many programmers would defend their assumptions well past the end of their lunch break. Two dubious assumptions that are easy to spot in code are "this method call can never fail" and "it doesn't matter if this call fails". When a programmer ignores an exception, they implicitly state that they are operating under one of these assumptions. **Example 1:** The following code excerpt ignores a rarely-thrown exception from `open()`.

```
try:
    f = open('myfile.txt')
    s = f.readline()
    i = int(s.strip())
except:
    # This will never happen
    pass
```

If a `RareException` were to ever be thrown, the program would continue to execute as though nothing unusual had occurred. The program records no evidence indicating the special situation, potentially frustrating any later attempt to explain the program's behavior.

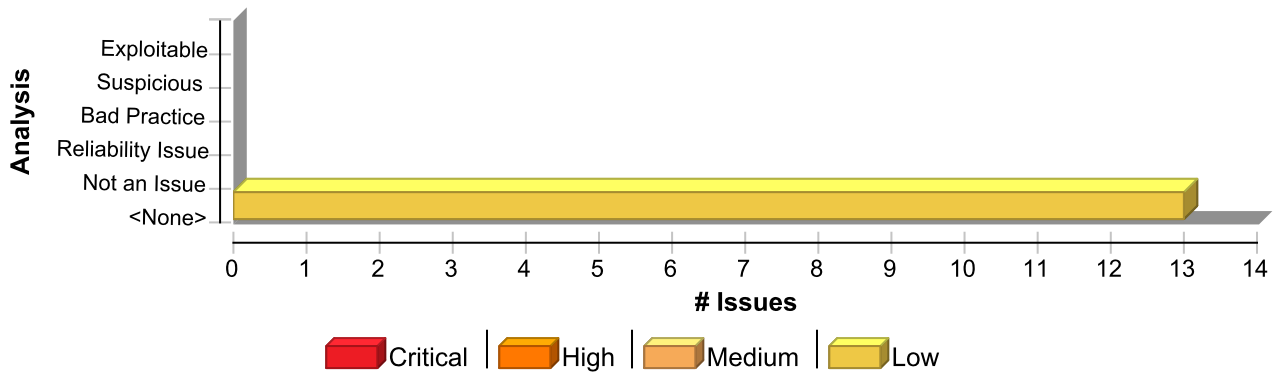
Recommendation

At a minimum, log the fact that the exception was thrown so that it will be possible to come back later and make sense of the resulting program behavior. Better yet, abort the current operation. If the exception is being ignored because the caller cannot properly handle it but the context makes it inconvenient or impossible for the caller to declare that it throws the exception itself, consider throwing a `RuntimeError` or an `Error`, both of which are unchecked exceptions. **Example 2:** The code in Example 1 could be rewritten in the following way:

```
try:
    f = open('myfile.txt')
    s = f.readline()
    i = int(s.strip())
except IOError as e:
    logging.error("I/O error({0}): {1}".format(e.errno, e.strerror))
except ValueError:
    logging.error("Could not convert data to an integer.")
except:
    logging.error("Unexpected error:", sys.exc_info()[0])
    raise
```

Issue Summary





Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Poor Error Handling: Empty Catch Block	13	0	0	13
Total	13	0	0	13

Poor Error Handling: Empty Catch Block

Low

Package: addons.auto_backup.models.db_backup

addons/auto_backup/models/db_backup.py, line 224 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors
Scan Engine: SCA (Structural)

Sink Details

Sink: CatchBlock
Enclosing Method: schedule_backup()
File: addons/auto_backup/models/db_backup.py:224
Taint Flags:

```
221 try:
222     sftp.close()
223     s.close()
224 except:
225     pass
226 _logger.error('Exception! We couldn\'t back up to the FTP server. Here is what we got
back '
227 'instead: %s', str(e))
```

addons/auto_backup/models/db_backup.py, line 245 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors
Scan Engine: SCA (Structural)

Sink Details



Poor Error Handling: Empty Catch Block

Low

Package: addons.auto_backup.models.db_backup

addons/auto_backup/models/db_backup.py, line 245 (Poor Error Handling: Empty Catch Block)

Sink: CatchBlock

Enclosing Method: schedule_backup()

File: addons/auto_backup/models/db_backup.py:245

Taint Flags:

```
242 ") failed",
243 message)
244 ir_mail_server.send_email(msg)
245 except Exception:
246 pass
247
248 # Remove all old files (on local server) in case this is configured..
```

Package: addons.etc_api.models.ir_attachment

addons/etc_api/models/ir_attachment.py, line 153 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details

Sink: CatchBlock

Enclosing Method: _validate_attachment_safety()

File: addons/etc_api/models/ir_attachment.py:153

Taint Flags:

```
150 raise ValidationError(_("Tá°fi lÃ°n thá°yt bá°;i: Ná»™i dung tá»p chá»a mã£ thá»tc thi
khÃ°ng há»fp lá»t."))
151 except ValidationError:
152 raise
153 except Exception:
154 pass
155
156 @api.model
```

addons/etc_api/models/ir_attachment.py, line 187 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details



Poor Error Handling: Empty Catch Block

Low

Package: addons.etc_api.models.ir_attachment

addons/etc_api/models/ir_attachment.py, line 187 (Poor Error Handling: Empty Catch Block)

Sink: CatchBlock

Enclosing Method: _validate_pdf_content()

File: addons/etc_api/models/ir_attachment.py:187

Taint Flags:

```
184 raise ValidationError(_("Tá°£i lÃ°n thá°¥t bá°;i: TÃ i liá»tu PDF chá»©a mÃ£ thá»±c thi
khÃ°ng an sau (%s).") % pattern.decode())
185 except ValidationError:
186 raise
187 except Exception:
188 pass
189
190 undefined
```

Package: addons.etc_api.models.ir_http

addons/etc_api/models/ir_http.py, line 50 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details

Sink: CatchBlock

Enclosing Method: binary_content()

File: addons/etc_api/models/ir_http.py:50

Taint Flags:

```
47 request.session.get_context()
48 # Cá°-p nhá°-t context environment cá»$a self
49 self = self.with_user(user)
50 except Exception:
51 pass
52
53 try:
```

Package: addons.etc_api.tools.http.api_management

addons/etc_api/tools/http.py, line 173 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details



Poor Error Handling: Empty Catch Block

Low

Package: addons.etc_api.tools.http.api_management

addons/etc_api/tools/http.py, line 173 (Poor Error Handling: Empty Catch Block)

Sink: CatchBlock

Enclosing Method: wrapper()

File: addons/etc_api/tools/http.py:173

Taint Flags:

```
170 try:
171     request.httprequest.data = decrypt(payload.encode('utf-8'))
172     request.data = json.loads(decrypt(payload.encode('utf-8')))
173 except Exception:
174     # For type='json' routes, body is already plain JSON (not encrypted).
175     # Odoo parses it into request.jsonrequest automatically.
176     # decrypt() will fail on plain JSON " that's expected, just skip.
```

Package: addons.etc_api.tools.validator

addons/etc_api/tools/validator.py, line 180 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details

Sink: CatchBlock

Enclosing Method: parse_request()

File: addons/etc_api/tools/validator.py:180

Taint Flags:

```
177 if 'Authorization' in headers:
178     try:
179         token = headers['Authorization'].split(' ')[1]
180     except Exception:
181         pass
182
183     return http_method, body, headers, token
```

Package: addons.etc_overtime_request.controllers.main

addons/etc_overtime_request/controllers/main.py, line 598 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details



Poor Error Handling: Empty Catch Block

Low

Package: addons.etc_overtime_request.controllers.main

addons/etc_overtime_request/controllers/main.py, line 598 (Poor Error Handling: Empty Catch Block)

Sink: CatchBlock

Enclosing Method: map_data()

File: addons/etc_overtime_request/controllers/main.py:598

Taint Flags:

```
595 if ci_co:
596     check_in = str(datetime.strptime(ci_co[0], '%H:%M:%S').time()) if ci_co[0] else ''
597     check_out = str(datetime.strptime(ci_co[-1], '%H:%M:%S').time()) if ci_co[-1] else ''
598     except Exception:
599     pass
600     check_in = 'N/a'
601     check_out = 'N/a'
```

addons/etc_overtime_request/controllers/main.py, line 615 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details

Sink: CatchBlock

Enclosing Method: map_data()

File: addons/etc_overtime_request/controllers/main.py:615

Taint Flags:

```
612 'ci/co': 'Giá» vÃ o: ' + check_in + ' - Giá» ra: ' + check_out,
613 'task_tfs': task_tfs
614 }
615 except Exception:
616     pass
617
618 return {
```

Package: addons.etc_timekeeping.models.etc_smartface_version

addons/etc_timekeeping/models/etc_smartface_version.py, line 32 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details



Poor Error Handling: Empty Catch Block

Low

Package: addons.etc_timekeeping.models.etc_smartface_version

addons/etc_timekeeping/models/etc_smartface_version.py, line 32 (Poor Error Handling: Empty Catch Block)

Sink: CatchBlock

Enclosing Method: unlink()

File: addons/etc_timekeeping/models/etc_smartface_version.py:32

Taint Flags:

```
29 full_path = f"{dir_path}{path}"
30 if os.path.exists(full_path):
31     os.remove(full_path)
32 except Exception as e:
33     pass
34 res = super(EtcSmartfaceVersion, self).unlink()
35 return res
```

Package: addons.hr_leave_request_aliasing.models.leave_request_alias

addons/hr_leave_request_aliasing/models/leave_request_alias.py, line 58 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details

Sink: CatchBlock

Enclosing Method: message_new()

File: addons/hr_leave_request_aliasing/models/leave_request_alias.py:58

Taint Flags:

```
55 'number_of_days': no_of_days_temp
56 })
57 return super(HrLeaveAlias, self).message_new(msg_dict, custom_values)
58 except:
59     pass
60
61 undefined
```

Package: addons.queue_job.jobrunner.channels

addons/queue_job/jobrunner/channels.py, line 121 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details



Poor Error Handling: Empty Catch Block

Low

Package: addons.queue_job.jobrunner.channels

addons/queue_job/jobrunner/channels.py, line 121 (Poor Error Handling: Empty Catch Block)

Sink: CatchBlock

Enclosing Method: remove()

File: addons/queue_job/jobrunner/channels.py:121

Taint Flags:

```
118 # pylint: disable=missing-return,except-pass
119 try:
120     super().remove(o)
121 except KeyError:
122     pass
123
124
```

Package: addons.queue_job.jobrunner.runner

addons/queue_job/jobrunner/runner.py, line 271 (Poor Error Handling: Empty Catch Block)

Issue Details

Kingdom: Errors

Scan Engine: SCA (Structural)

Sink Details

Sink: CatchBlock

Enclosing Method: close()

File: addons/queue_job/jobrunner/runner.py:271

Taint Flags:

```
268 # del
269 try:
270     self.conn.close()
271 except Exception:
272     pass
273     self.conn = None
274
```

Portability Flaw: File Separator (2 issues)

Abstract

The use of hardcoded file separators causes portability problems.

Explanation

Different operating systems use different characters as file separators. For example, Microsoft Windows systems use "\", while UNIX systems use "/". When applications have to run on different platforms, the use of hardcoded file separators can lead to incorrect execution of application logic and potentially a denial of service. **Example 1:** The following code uses a hardcoded file separator to open a file:

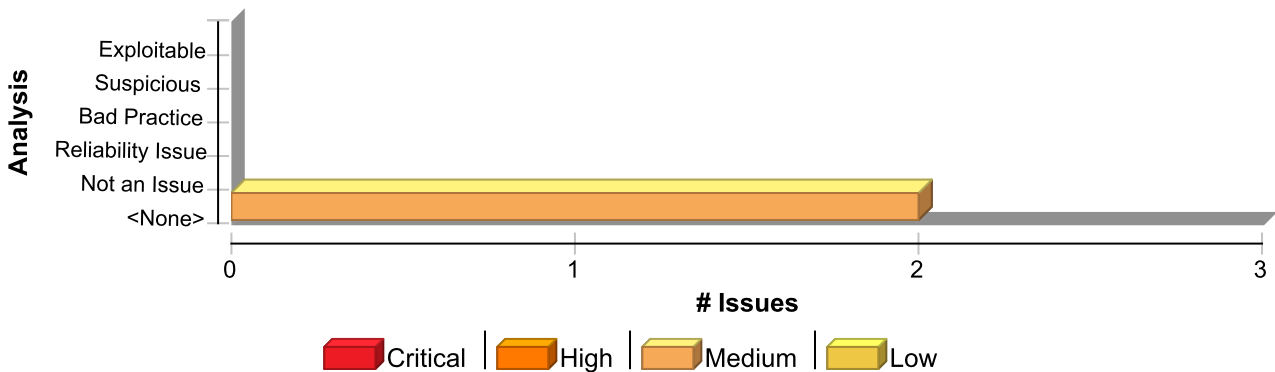
```
...
os.open(directoryName + "\\\" + fileName);
...
```

Recommendation

In order to write portable code, avoid using hardcoded file separators. Instead, rely on platform-independent APIs provided by the language library. **Example 2:** The following code implements the same functionality as Example 1, but uses platform-independent API to specify a file separator:

```
...
os.open(os.path.join(directoryName, fileName));
...
```

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Portability Flaw: File Separator	2	0	0	2
Total	2	0	0	2

Portability Flaw: File SeparatorMedium

Package: addons.etc_air_conditioner_request.models.etc_air_conditioner_request

addons/etc_air_conditioner_request/models/etc_air_conditioner_request.py, line 263 (Portability Flaw: File Separator)

Issue Details



Portability Flaw: File Separator**Medium****Package:** addons.etc_air_conditioner_request.models.etc_air_conditioner_request**addons/etc_air_conditioner_request/models/etc_air_conditioner_request.py, line 263 (Portability Flaw: File Separator)****Kingdom:** Code Quality**Scan Engine:** SCA (Data Flow)**Source Details****Source:** Read**From:** addons.etc_air_conditioner_request.models.etc_air_conditioner_request.EtcRegisterAirConditioner._generate_pdf_air_conditioner_request**File:** addons/etc_air_conditioner_request/models/etc_air_conditioner_request.py:253

```
250 rec._generate_pdf_air_conditioner_request()
251
252 def _generate_pdf_air_conditioner_request(self):
253 pdf_path = FOLDER + "Giá°¥y Ä`Äfng kÃ½ lÃ m thÃªm ngoÃ i giá»¿.pdf"
254 self._generate_pdf_overtime_register(pdf_path)
255 if os.path.exists(pdf_path):
256 with open(pdf_path, "rb") as file:
```

Sink Details**Sink:** os.remove()**Enclosing Method:** _generate_pdf_air_conditioner_request()**File:** addons/etc_air_conditioner_request/models/etc_air_conditioner_request.py:263**Taint Flags:** FILESEPARATOR

```
260 'advance_filename': "Giá°¥y Ä`Äfng kÃ½ lÃ m thÃªm ngoÃ i giá»¿.pdf"
261 })
262 if os.path.exists(pdf_path):
263 os.remove(pdf_path)
264
265 def _generate_pdf_overtime_register(self, pdf_path):
266 request_date = datetime.strptime(self.request_date, '%d/%m/%Y')
```

Package: addons.etc_form_management.models.etc_advance_request**addons/etc_form_management/models/etc_advance_request.py, line 621 (Portability Flaw: File Separator)****Issue Details****Kingdom:** Code Quality**Scan Engine:** SCA (Data Flow)**Source Details****Source:** Read**From:** addons.etc_form_management.models.etc_advance_request.EtcAdvanceRequest._generate_pdf_advance_form**File:** addons/etc_form_management/models/etc_advance_request.py:611

Portability Flaw: File Separator**Medium****Package:** addons.etc_form_management.models.etc_advance_request**addons/etc_form_management/models/etc_advance_request.py, line 621**
(Portability Flaw: File Separator)

```
608 return self._return_act_url_download_file()
609
610 def _generate_pdf_advance_form(self):
611     pdf_path = FOLDER + 'Phiá°;u tá°;m á»©ng.pdf'
612     self._generate_pdf_advance(pdf_path)
613     if os.path.exists(pdf_path):
614         with open(pdf_path, "rb") as file:
```

Sink Details**Sink:** os.remove()**Enclosing Method:** _generate_pdf_advance_form()**File:** addons/etc_form_management/models/etc_advance_request.py:621**Taint Flags:** FILESEPARATOR

```
618 'advance_filename': "Giá°¥y Ä'á»¤ nghá»< tá°;m á»©ng.pdf"
619 })
620 if os.path.exists(pdf_path):
621     os.remove(pdf_path)
622
623 def _generate_pdf_advance(self, pdf_path):
624     bank_transfer = ''
```

Privacy Violation (2 issues)

Abstract

Mishandling private information, such as customer passwords or social security numbers, can compromise user privacy and is often illegal.

Explanation

Privacy violations occur when: 1. Private user information enters the program. 2. The data is written to an external location, such as the console, file system, or network. **Example 1:** The following code contains a logging statement that tracks the contents of records added to a database by storing them in a log file. Among other values that are stored is the return value from the `getPassword()` function that returns user-supplied plain text password associated with the account.

```
pass = getPassword();  
logger.warning('%s: %s %s %s', id, pass, type, tsstamp)
```

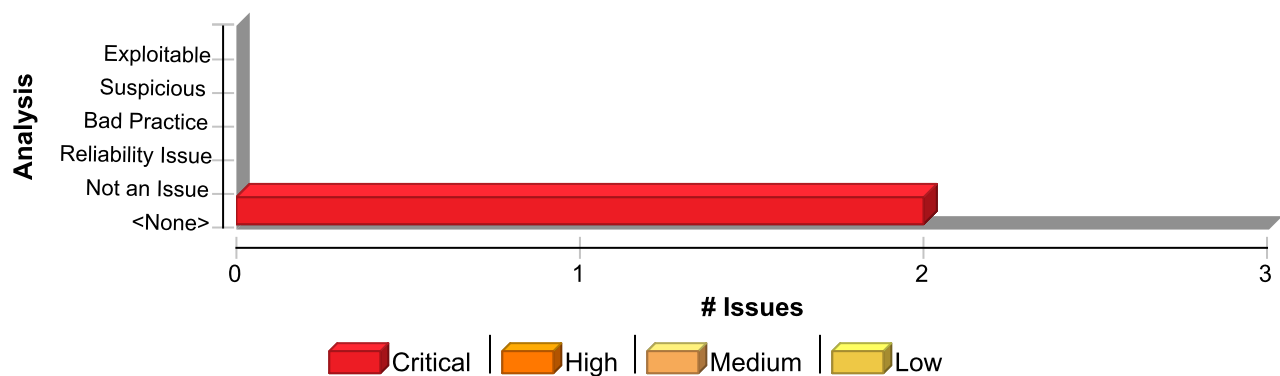
The code in Example 1 logs a plain text password to the application eventlog. Although many developers trust the eventlog as a safe storage location for data, it should not be trusted implicitly, particularly when privacy is a concern. Private data can enter a program in a variety of ways: - Directly from the user in the form of a password or personal information - Accessed from a database or other data store by the application - Indirectly from a partner or other third party Sometimes data that is not labeled as private can have a privacy implication in a different context. For example, student identification numbers are usually not considered private because there is no explicit and publicly-available mapping to an individual student's personal information. However, if a school generates identification numbers based on student social security numbers, then the identification numbers should be considered private. Security and privacy concerns often seem to compete with each other. From a security perspective, you should record all important operations so that any anomalous activity can later be identified. However, when private data is involved, this practice can create risk. Although there are many ways in which private data can be handled unsafely, a common risk stems from misplaced trust. Programmers often trust the operating environment in which a program runs, and therefore believe that it is acceptable to store private information on the file system, in the registry, or in other locally-controlled resources. However, even if access to certain resources is restricted, this does not guarantee that the individuals who do have access can be trusted. For example, in 2004, an unscrupulous employee at AOL sold approximately 92 million private customer email addresses to a spammer marketing an offshore gambling web site [1]. In response to such high-profile exploits, the collection and management of private data is becoming increasingly regulated. Depending on its location, the type of business it conducts, and the nature of any private data it handles, an organization may be required to comply with one or more of the following federal and state regulations: - Safe Harbor Privacy Framework [3] - Gramm-Leach Bliley Act (GLBA) [4] - Health Insurance Portability and Accountability Act (HIPAA) [5] - California SB-1386 [6] Despite these regulations, privacy violations continue to occur with alarming frequency.

Recommendation

When security and privacy demands clash, privacy should usually be given the higher priority. To accomplish this and still maintain required security information, cleanse any private information before it exits the program. To enforce good privacy management, develop and strictly adhere to internal privacy guidelines. The guidelines should specifically describe how an application should handle private data. If your organization is regulated by federal or state law, ensure that your privacy guidelines are sufficiently strenuous to meet the legal requirements. Even if your organization is not regulated, you must protect private information or risk losing customer confidence. The best policy with respect to private data is to minimize its exposure. Applications, processes, and employees should not be granted access to any private data unless the access is required for the tasks that they are to perform. Just as the principle of least privilege dictates that no operation should be performed with more than the necessary privileges, access to private data should be restricted to the smallest possible group.



Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Privacy Violation	2	0	0	2
Total	2	0	0	2

Privacy ViolationCritical

Package: addons.oh_hr_zk_attendance.models.zkuser

addons/oh_hr_zk_attendance/models/zkuser.py, line 38 (Privacy Violation)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Data Flow)

Source Details

Source: Read password
From: addons.oh_hr_zk_attendance.models.zkuser.zksetuser
File: addons/oh_hr_zk_attendance/models/zkuser.py:30

```
27 # constraint from the device vendor (ZKTeco). Cannot hash without
breaking device
28 # authentication. Compensating controls: device on isolated VLAN,
firewall ACL
29 # restricts traffic to Odoo server <-> ZK device only.
30 command_string = pack('sxs8s28ss7sx8s16s', chr( uid ), chr(role),
password, name, chr(1), '', userid, '' )
31 chksum = 0
32 session_id = self.session_id
33 reply_id = unpack('HHHH', self.data_recv[:8])[3]
```

Sink Details

Sink: socket._socketobject.sendto()
Enclosing Method: zksetuser()
File: addons/oh_hr_zk_attendance/models/zkuser.py:38
Taint Flags: PRIVATE



Privacy Violation

Critical

Package: addons.oh_hr_zk_attendance.models.zkuser

addons/oh_hr_zk_attendance/models/zkuser.py, line 38 (Privacy Violation)

```
35 buf = self.createHeader(command, chksum, session_id,  
36 reply_id, command_string)  
37 _logger.debug('Sending user data to ZK device (password masked)')  
38 self.zkclient.sendto(buf, self.address) # Fortify Suppress: Privacy Violation  
39 try:  
40 self.data_recv, addr = self.zkclient.recvfrom(1024)  
41 self.session_id = unpack('HHHH', self.data_recv[:8])[2]
```

addons/oh_hr_zk_attendance/models/zkuser.py, line 38 (Privacy Violation)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Data Flow)

Source Details

Source: Read password
From: addons.oh_hr_zk_attendance.models.zklib.ZKLib.setUser
File: addons/oh_hr_zk_attendance/models/zklib.py:139

```
136 def setUser(self, uid, userid, name, password, role):  
137 # Fortify Suppress: Privacy Violation - password passed to zksetuser  
which  
138 # requires plaintext per ZK device protocol. See zkuser.py for full  
justification.  
139 return zksetuser(self, uid, userid, name, password, role)  
140  
141 def clearUser(self):  
142 return zkcLEARuser(self)
```

Sink Details

Sink: socket._socketobject.sendto()
Enclosing Method: zksetuser()
File: addons/oh_hr_zk_attendance/models/zkuser.py:38
Taint Flags: PRIVATE

```
35 buf = self.createHeader(command, chksum, session_id,  
36 reply_id, command_string)  
37 _logger.debug('Sending user data to ZK device (password masked)')  
38 self.zkclient.sendto(buf, self.address) # Fortify Suppress: Privacy Violation  
39 try:  
40 self.data_recv, addr = self.zkclient.recvfrom(1024)  
41 self.session_id = unpack('HHHH', self.data_recv[:8])[2]
```



System Information Leak: Internal (21 issues)

Abstract

Revealing system data or debugging information could enable an adversary to use system information to plan an attack.

Explanation

An internal information leak occurs when system data or debug information is sent to a local file, console, or screen via printing or logging. **Example 1:** The following code writes an exception to the standard output stream:

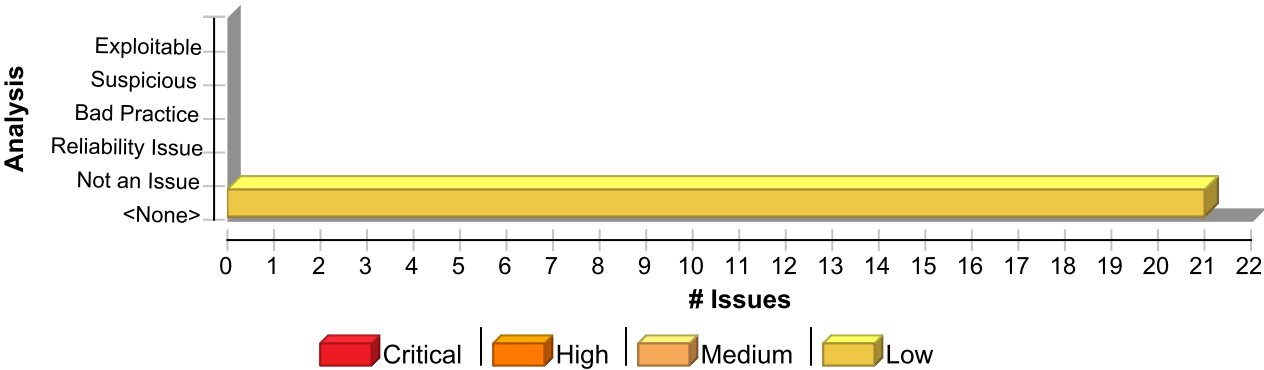
```
try:
    ...
except:
    print(sys.exc_info()[2])
```

This information is dumped to a console. In some cases, the error message provides the attacker with the precise type of attack to which the system is vulnerable. For example, a database error message can reveal that the application is vulnerable to a SQL injection attack. Other error messages can reveal more oblique clues about the system. In Example 1, the leaked information could imply information about the type of operating system, the applications installed on the system, and the amount of care that the administrators have put into configuring the program.

Recommendation

Write error messages with security in mind. In production environments, turn off detailed error information in favor of brief messages. Restrict the generation and storage of detailed output that can help administrators and programmers diagnose problems. Debug traces can sometimes appear in non-obvious places (embedded in comments in the HTML for an error page, for example). Even brief error messages that do not reveal stack traces or database dumps can potentially aid an attacker. For example, an "Access Denied" message can reveal that a file or user exists on the system.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
System Information Leak: Internal	21	0	0	21
Total	21	0	0	21



Package: .src.js

addons/etc_fleet_vehicle/static/src/js/fleet_vehicle_map.js, line 72 (System Information Leak: Internal)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: lambda(0)
From: lambda
File: addons/etc_fleet_vehicle/static/src/js/fleet_vehicle_map.js:71

```
68  if (!data || !Array.isArray(data)) return;  
69  data.forEach(v => self._updateMarker(v));  
70  })  
71  .catch(err => {  
72    console.error(err);  
73  });  
74  },
```

Sink Details

Sink: ~JS_Generic.error()
Enclosing Method: lambda()
File: addons/etc_fleet_vehicle/static/src/js/fleet_vehicle_map.js:72
Taint Flags: SYSTEMINFO

```
69  data.forEach(v => self._updateMarker(v));  
70  })  
71  .catch(err => {  
72    console.error(err);  
73  });  
74  },  
75
```

Package: addons.etc_asset.models.etc_asset_inventory

addons/etc_asset/models/etc_asset_inventory.py, line 135 (System Information Leak: Internal)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_asset.models.etc_asset_inventory.EtcInventoryAssetTable.check_inventory
File: addons/etc_asset/models/etc_asset_inventory.py:134



System Information Leak: Internal**Low****Package:** addons.etc_asset.models.etc_asset_inventory**addons/etc_asset/models/etc_asset_inventory.py, line 135 (System Information Leak: Internal)**

```
131 inventoryAssetData.sudo().update({'is_checked': True})
132
133 print('====End_check_inventory====')
134 except Exception as e:
135 print('check_inventory', str(e))
136
137 undefined
```

Sink Details**Sink:** print()**Enclosing Method:** check_inventory()**File:** addons/etc_asset/models/etc_asset_inventory.py:135**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
132
133 print('====End_check_inventory====')
134 except Exception as e:
135 print('check_inventory', str(e))
136
137 undefined
138 undefined
```

Package: addons.etc_booking_room.models.etc_booking_rooms**addons/etc_booking_room/models/etc_booking_rooms.py, line 417 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_booking_room.models.etc_booking_rooms.EtcBookingRoom.handle_create_participants_and_guest**File:** addons/etc_booking_room/models/etc_booking_rooms.py:416

System Information Leak: Internal**Low****Package:** addons.etc_booking_room.models.etc_booking_rooms**addons/etc_booking_room/models/etc_booking_rooms.py, line 417 (System Information Leak: Internal)**

```
413 img_str = base64.b64encode(buffered.getvalue()).decode("utf-8")
414 guest['qr_code'] = img_str
415 BookingRoomGuestService.sudo().create(guest)
416 except Exception as err:
417 print('err', err)
418 # TO DO send email
419 # BookingRoomGuest.send_email_to_guest(booking_room_record, guest)
```

Sink Details**Sink:** print()**Enclosing Method:** handle_create_participants_and_guest()**File:** addons/etc_booking_room/models/etc_booking_rooms.py:417**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
414 guest['qr_code'] = img_str
415 BookingRoomGuestService.sudo().create(guest)
416 except Exception as err:
417 print('err', err)
418 # TO DO send email
419 # BookingRoomGuest.send_email_to_guest(booking_room_record, guest)
420
```

addons/etc_booking_room/models/etc_booking_rooms.py, line 381 (System Information Leak: Internal)**Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_booking_room.models.etc_booking_rooms.EtcBookingRoom.handle_create_participants_and_guest**File:** addons/etc_booking_room/models/etc_booking_rooms.py:380

```
377 'employee_id': participant,
378 'status': constants.STATUS_BOOKING_ROOM_SPENDING,
379 })
380 except Exception as err:
381 print(err)
382 else:
383 continue
```

Sink Details

System Information Leak: Internal**Low****Package:** addons.etc_booking_room.models.etc_booking_rooms**addons/etc_booking_room/models/etc_booking_rooms.py, line 381 (System Information Leak: Internal)**

Sink: print()
Enclosing Method: handle_create_participants_and_guest()
File: addons/etc_booking_room/models/etc_booking_rooms.py:381
Taint Flags: EXCEPTIONINFO, SYSTEMINFO

```
378 'status': constants.STATUS_BOOKING_ROOM_SPENDING,  
379 })  
380 except Exception as err:  
381 print(err)  
382 else:  
383 continue  
384
```

addons/etc_booking_room/models/etc_booking_rooms.py, line 344 (System Information Leak: Internal)**Issue Details**

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_booking_room.models.etc_booking_rooms.EtcBookingRoom.open_door_to_employees
File: addons/etc_booking_room/models/etc_booking_rooms.py:343

```
340 })  
341 if response.status_code == 200:  
342 print('Má»Ỗ cá»-a thanh cÃ'ng')  
343 except Exception as e:  
344 print('Register smart face employee error', e)  
345  
346 # payload smartface nhÃ£n viÃªn
```

Sink Details

Sink: print()
Enclosing Method: open_door_to_employees()
File: addons/etc_booking_room/models/etc_booking_rooms.py:344
Taint Flags: EXCEPTIONINFO, SYSTEMINFO



System Information Leak: Internal**Low****Package: addons.etc_booking_room.models.etc_booking_rooms****addons/etc_booking_room/models/etc_booking_rooms.py, line 344 (System Information Leak: Internal)**

```
341 if response.status_code == 200:
342     print('Má»Ỗ cá»-a thanh cÃ'ng')
343     except Exception as e:
344     print('Register smart face employee error', e)
345
346 # payload smartface nhÃ¢n viÃªn
347 def get_payload_open_door_to_employees(self, record_booking, booking_user):
```

Package: addons.etc_cron_create_account_employee.models.etc_create_account_employee**addons/etc_cron_create_account_employee/models/etc_create_account_employee.py, line 130 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_cron_create_account_employee.models.etc_create_account_employee.ETCreateAccountEmployee.create_account_employee**File:** addons/etc_cron_create_account_employee/models/etc_create_account_employee.py:129

```
126 continue
127 else:
128 continue
129 except Exception as e:
130 print('Error=>>', e)
131
132 print("<<<<===End create account employee===>>>>")
```

Sink Details**Sink:** print()**Enclosing Method:** create_account_employee()**File:** addons/etc_cron_create_account_employee/models/etc_create_account_employee.py:130**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
127 else:
128 continue
129 except Exception as e:
130 print('Error=>>', e)
131
132 print("<<<<===End create account employee===>>>>")
133
```



System Information Leak: Internal**Low**

Package: addons.etc_cron_create_account_employee.models.etc_create_account_employee
addons/etc_cron_create_account_employee/models/
etc_create_account_employee.py, line 125 (System Information Leak: Internal)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_cron_create_account_employee.models.etc_create_account_employee.ET
CCreateAccountEmployee.create_account_employee
File: addons/etc_cron_create_account_employee/models/etc_create_account_employee.py
:124

```
121 # # disable user
122 # conn.modify(currentUser, {'userAccountControl': [('MODIFY_REPLACE',
123 2)]})
124 except Exception as e:
125 print('Create Account AD error', e)
126 continue
127 else:
```

Sink Details

Sink: print()
Enclosing Method: create_account_employee()
File: addons/etc_cron_create_account_employee/models/etc_create_account_employee.py:125
Taint Flags: EXCEPTIONINFO, SYSTEMINFO

```
122 # conn.modify(currentUser, {'userAccountControl': [('MODIFY_REPLACE', 2)]})
123
124 except Exception as e:
125 print('Create Account AD error', e)
126 continue
127 else:
128 continue
```

Package: addons.etc_cron_disable_account.models.etc_cron

addons/etc_cron_disable_account/models/etc_cron.py, line 34 (System
Information Leak: Internal)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

System Information Leak: Internal**Low****Package:** addons.etc_cron_disable_account.models.etc_cron**addons/etc_cron_disable_account/models/etc_cron.py, line 34 (System Information Leak: Internal)****Source:** __python_get_last_exception()**From:** addons.etc_cron_disable_account.models.etc_cron.CronJob.disable_account_when_employee_leave**File:** addons/etc_cron_disable_account/models/etc_cron.py:33

```
30 'jobStatus': 'nv',
31 'expriedContract': item.expected_revealing_date,
32 })
33 except Exception as e:
34 print('An exception occurred', e)
35
36 account_arr = []
```

Sink Details**Sink:** print()**Enclosing Method:** disable_account_when_employee_leave()**File:** addons/etc_cron_disable_account/models/etc_cron.py:34**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
31 'expriedContract': item.expected_revealing_date,
32 })
33 except Exception as e:
34 print('An exception occurred', e)
35
36 account_arr = []
37 # nhÃ¢n viÃªn nhÃ¡»% viÃ¡»tc Ä'Æ°á»£c duyá»tt bá°£ng nhÃ¢n viÃªn
```

addons/etc_cron_disable_account/models/etc_cron.py, line 54 (System Information Leak: Internal)**Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_cron_disable_account.models.etc_cron.CronJob.disable_account_when_employee_leave**File:** addons/etc_cron_disable_account/models/etc_cron.py:53

System Information Leak: Internal**Low****Package:** addons.etc_cron_disable_account.models.etc_cron**addons/etc_cron_disable_account/models/etc_cron.py, line 54 (System Information Leak: Internal)**

```
50 CronJob.action_register_departure(self, item, today)
51
52 account_arr.append(item.account)
53 except Exception as e:
54 print('An exception occurred', e)
55
56 print("<<<<===End Emp Disable=>>>>", account_arr)
```

Sink Details**Sink:** print()**Enclosing Method:** disable_account_when_employee_leave()**File:** addons/etc_cron_disable_account/models/etc_cron.py:54**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
51
52 account_arr.append(item.account)
53 except Exception as e:
54 print('An exception occurred', e)
55
56 print("<<<<===End Emp Disable=>>>>", account_arr)
57
```

Package: addons.etc_hr_insurance.models.models**addons/etc_hr_insurance/models/models.py, line 230 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_hr_insurance.models.models.ETCEmployeeInsurance.action_send_request**File:** addons/etc_hr_insurance/models/models.py:229

System Information Leak: Internal**Low****Package:** addons.etc_hr_insurance.models.models**addons/etc_hr_insurance/models/models.py, line 230 (System Information Leak: Internal)**

```
226 try:
227     self.export_xlsx(accessToken, data, employeeName, employeeAccount,
employeeDepartment, employeeContractType, employeeRequestType, manager_email,
url_approve)
228
229 except Exception as e:
230     print(e)
231     raise exceptions.ValidationError(e)
232
```

Sink Details**Sink:** print()**Enclosing Method:** action_send_request()**File:** addons/etc_hr_insurance/models/models.py:230**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
227 self.export_xlsx(accessToken, data, employeeName, employeeAccount, employeeDepartment,
employeeContractType, employeeRequestType, manager_email, url_approve)
228
229 except Exception as e:
230     print(e)
231     raise exceptions.ValidationError(e)
232
233 else:
```

Package:**addons.etc_inform_expired_lunch_payment_cron_job.models.etc_inform_expired_lunch_payment****addons/etc_inform_expired_lunch_payment_cron_job/models/
etc_inform_expired_lunch_payment.py, line 48 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_inform_expired_lunch_payment_cron_job.models.etc_inform_expired_lu
nch_payment.EtcInformExpiredLunChPayment.check_epay_payment_status**File:** addons/etc_inform_expired_lunch_payment_cron_job/models/etc_inform_expired_lu
nch_payment.py:47

System Information Leak: Internal**Low****Package:****addons.etc_inform_expired_lunch_payment_cron_job.models.etc_inform_expired_lunch_payment****addons/etc_inform_expired_lunch_payment_cron_job/models/etc_inform_expired_lunch_payment.py, line 48 (System Information Leak: Internal)**

```
44 if len(etc_payment_history) > 0:
45     for payment in etc_payment_history:
46         self.env['etc.payment.history'].sudo().check_status_payment_model(payment['order_id'])
47     except Exception as err:
48         print("=====Err update epay payment=====>", err)
49
50 def handle_send_notify_lunch_payment(self, current_date, last_day_of_prev_month):
```

Sink Details**Sink:** print()**Enclosing Method:** check_epay_payment_status()**File:** addons/etc_inform_expired_lunch_payment_cron_job/models/etc_inform_expired_lunch_payment.py:48**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
45 for payment in etc_payment_history:
46     self.env['etc.payment.history'].sudo().check_status_payment_model(payment['order_id'])
47 except Exception as err:
48     print("=====Err update epay payment=====>", err)
49
50 def handle_send_notify_lunch_payment(self, current_date, last_day_of_prev_month):
51     query = ''
```

Package: addons.etc_ldap.controllers.main**addons/etc_ldap/controllers/main.py, line 77 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_ldap.controllers.main.MainController.sync_ldap_etc_api**File:** addons/etc_ldap/controllers/main.py:76

System Information Leak: Internal**Low****Package:** addons.etc_ldap.controllers.main**addons/etc_ldap/controllers/main.py, line 77 (System Information Leak: Internal)**

```
73 }
74 print('new_emp', new_emp)
75 request.env['hr.employee'].sudo().create(new_emp)
76 except Exception as e:
77 print('exception', e)
78 return make_json_loads(msg='Sync thất bại; i' ,data=e)
79 except Exception as e:
```

Sink Details

Sink: print()
Enclosing Method: sync_ldap_etc_api()
File: addons/etc_ldap/controllers/main.py:77
Taint Flags: EXCEPTIONINFO, SYSTEMINFO

```
74 print('new_emp', new_emp)
75 request.env['hr.employee'].sudo().create(new_emp)
76 except Exception as e:
77 print('exception', e)
78 return make_json_loads(msg='Sync thất bại; i' ,data=e)
79 except Exception as e:
80 print('An exception occurred SYNC_LDAP', e)
```

addons/etc_ldap/controllers/main.py, line 80 (System Information Leak: Internal)**Issue Details**

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_ldap.controllers.main.MainController.sync_ldap_etc_api
File: addons/etc_ldap/controllers/main.py:79

```
76 except Exception as e:
77 print('exception', e)
78 return make_json_loads(msg='Sync thất bại; i' ,data=e)
79 except Exception as e:
80 print('An exception occurred SYNC_LDAP', e)
81 print('=====END SYNC VIA API=====')
82
```

Sink Details

System Information Leak: Internal**Low****Package:** addons.etc_ldap.controllers.main**addons/etc_ldap/controllers/main.py, line 80 (System Information Leak: Internal)**

Sink: print()
Enclosing Method: sync_ldap_etc_api()
File: addons/etc_ldap/controllers/main.py:80
Taint Flags: EXCEPTIONINFO, SYSTEMINFO

```
77 print('exception', e)
78 return make_json_loads(msg='Sync thất bại' ,data=e)
79 except Exception as e:
80 print('An exception occurred SYNC_LDAP', e)
81 print('=====END SYNC VIA API=====')
82
83 undefined
```

Package: addons.etc_ldap.models.etc_ldap**addons/etc_ldap/models/etc_ldap.py, line 65 (System Information Leak: Internal)****Issue Details**

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_ldap.models.etc_ldap.CronJobSyncLdap.sync_ldap_etc
File: addons/etc_ldap/models/etc_ldap.py:64

```
61 self.env['hr.employee'].sudo().create(new_emp)
62 except Exception as e:
63 print('exception', e)
64 except Exception as e:
65 print('An exception occurred SYNC_LDAP', e)
66 print('=====END SYNC=====')
67
```

Sink Details

Sink: print()
Enclosing Method: sync_ldap_etc()
File: addons/etc_ldap/models/etc_ldap.py:65
Taint Flags: EXCEPTIONINFO, SYSTEMINFO



Package: addons.etc_ldap.models.etc_ldap

addons/etc_ldap/models/etc_ldap.py, line 65 (System Information Leak: Internal)

```
62 except Exception as e:
63 print('exception', e)
64 except Exception as e:
65 print('An exception occurred SYNC_LDAP', e)
66 print('=====END SYNC=====')
67
68 def handler_job_id(self, job):
```

addons/etc_ldap/models/etc_ldap.py, line 63 (System Information Leak: Internal)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_ldap.models.etc_ldap.CronJobSyncLdap.sync_ldap_etc
File: addons/etc_ldap/models/etc_ldap.py:62

```
59 }
60 print('new_emp', new_emp)
61 self.env['hr.employee'].sudo().create(new_emp)
62 except Exception as e:
63 print('exception', e)
64 except Exception as e:
65 print('An exception occurred SYNC_LDAP', e)
```

Sink Details

Sink: print()
Enclosing Method: sync_ldap_etc()
File: addons/etc_ldap/models/etc_ldap.py:63
Taint Flags: EXCEPTIONINFO, SYSTEMINFO

```
60 print('new_emp', new_emp)
61 self.env['hr.employee'].sudo().create(new_emp)
62 except Exception as e:
63 print('exception', e)
64 except Exception as e:
65 print('An exception occurred SYNC_LDAP', e)
66 print('=====END SYNC=====')
```

Package: addons.etc_leave_request.models.etc_leave

addons/etc_leave_request/models/etc_leave.py, line 919 (System Information Leak: Internal)

Issue Details



System Information Leak: Internal	Low
Package: addons.etc_leave_request.models.etc_leave	
addons/etc_leave_request/models/etc_leave.py, line 919 (System Information Leak: Internal)	

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_leave_request.models.etc_leave.LeaveRequests.handle_remaining_employee_day_off
File: addons/etc_leave_request/models/etc_leave.py:918

```
915 time_off = self.busday_count_range(start_date, end_date)
916 remaining_day_off = remaining_day_off - time_off
917 current_employee.remaining_day_off = remaining_day_off if
remaining_day_off >= 0 else 0
918 except Exception as error:
919 print('error', error)
920 FirebaseConstants.send_one_notify(res.employee_id.device_id,
SmartFaceConstants.TITLE_NOTIFY_LEAVE_REQUEST, body,
SmartFaceConstants.TYPE_NOTIFY_LEAVE_REQUEST)
921
```

Sink Details

Sink: print()
Enclosing Method: handle_remaining_employee_day_off()
File: addons/etc_leave_request/models/etc_leave.py:919
Taint Flags: EXCEPTIONINFO, SYSTEMINFO

```
916 remaining_day_off = remaining_day_off - time_off
917 current_employee.remaining_day_off = remaining_day_off if remaining_day_off >= 0 else 0
918 except Exception as error:
919 print('error', error)
920 FirebaseConstants.send_one_notify(res.employee_id.device_id,
SmartFaceConstants.TITLE_NOTIFY_LEAVE_REQUEST, body,
SmartFaceConstants.TYPE_NOTIFY_LEAVE_REQUEST)
921
922 undefined
```

Package: addons.etc_payslip.controllers.controllers
addons/etc_payslip/controllers/controllers.py, line 122 (System Information Leak: Internal)

Issue Details

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details



System Information Leak: Internal**Low****Package:** addons.etc_payslip.controllers.controllers**addons/etc_payslip/controllers/controllers.py, line 122 (System Information Leak: Internal)****Source:** __python_get_last_exception()**From:** addons.etc_payslip.controllers.controllers.MainController.export_tax_report**File:** addons/etc_payslip/controllers/controllers.py:121

```
118 print("The file does not exist")
119
120 return response
121 except Exception as e:
122 print('An exception occurred', e)
123
124 @http.route("/api/v1/payslip/<string:payslip_id>", type='http',
auth='public', csrf=False, cors='*', methods=['GET'])
```

Sink Details**Sink:** print()**Enclosing Method:** export_tax_report()**File:** addons/etc_payslip/controllers/controllers.py:122**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
119
120 return response
121 except Exception as e:
122 print('An exception occurred', e)
123
124 @http.route("/api/v1/payslip/<string:payslip_id>", type='http', auth='public',
csrf=False, cors='*', methods=['GET'])
125 @api_management()
```

Package: addons.etc_send_all_qr_employee_job.models.etc_send_qr_code_employee**addons/etc_send_all_qr_employee_job/models/etc_send_qr_code_employee.py, line 24 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_send_all_qr_employee_job.models.etc_send_qr_code_employee.EtcSendQ
rCodeEmployee.send_qr_code_employee**File:** addons/etc_send_all_qr_employee_job/models/etc_send_qr_code_employee.py:23

System Information Leak: Internal**Low****Package:** addons.etc_send_all_qr_employee_job.models.etc_send_qr_code_employee**addons/etc_send_all_qr_employee_job/models/etc_send_qr_code_employee.py, line 24 (System Information Leak: Internal)**

```
20 otp_hash = crypto.encryptData(key_otp,
twoFactorAuthenticationConstants.TWO_FACTOR_AUTHENTICATION_SECRET_KEY)
21 employee.otp_key = otp_hash
22 self.env['hr.employee'].sudo().send_email_qr_code_employee(key_otp,
employee)
23 except Exception as err:
24 print('err==>', err)
25
26 undefined
```

Sink Details**Sink:** print()**Enclosing Method:** send_qr_code_employee()**File:** addons/etc_send_all_qr_employee_job/models/etc_send_qr_code_employee.py:24**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
21 employee.otp_key = otp_hash
22 self.env['hr.employee'].sudo().send_email_qr_code_employee(key_otp, employee)
23 except Exception as err:
24 print('err==>', err)
25
26 undefined
27 undefined
```

Package: addons.etc_smart_face.models.models**addons/etc_smart_face/models/models.py, line 521 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**From:** addons.etc_smart_face.models.models.SmartFaceModule.register_employee_smart_face_lunch**File:** addons/etc_smart_face/models/models.py:520

System Information Leak: Internal**Low****Package:** addons.etc_smart_face.models.models**addons/etc_smart_face/models/models.py, line 521 (System Information Leak: Internal)**

```
517 })
518 if response.status_code == 200:
519     print('Register smartface employee successfully')
520 except Exception as e:
521     print('Register smart face employee error', e)
522
523 # payload má»Ỗ cá»-a cho nhÃ¢n viÃªn dÆ°á»>i bá»p Äfn
```

Sink Details

Sink: print()
Enclosing Method: register_employee_smart_face_lunch()
File: addons/etc_smart_face/models/models.py:521
Taint Flags: EXCEPTIONINFO, SYSTEMINFO

```
518 if response.status_code == 200:
519     print('Register smartface employee successfully')
520 except Exception as e:
521     print('Register smart face employee error', e)
522
523 # payload má»Ỗ cá»-a cho nhÃ¢n viÃªn dÆ°á»>i bá»p Äfn
524 def get_payload_register_employee_smart_face_lunch(self, employee, lunch_shifts):
```

Package: addons.etc_working_calendar.models.etc_working_calendar**addons/etc_working_calendar/models/etc_working_calendar.py, line 512 (System Information Leak: Internal)****Issue Details**

Kingdom: Encapsulation
Scan Engine: SCA (Data Flow)

Source Details

Source: __python_get_last_exception()
From: addons.etc_working_calendar.models.etc_working_calendar.EtcWorkingCalendar.get_user_working_calendar
File: addons/etc_working_calendar/models/etc_working_calendar.py:511



System Information Leak: Internal**Low****Package:** addons.etc_working_calendar.models.etc_working_calendar**addons/etc_working_calendar/models/etc_working_calendar.py, line 512**
(System Information Leak: Internal)

```
508 data[item['workDate']]['total_hours'] = data[item['workDate']]
    ['total_hours'] + item['workingHours']
509 data[item['workDate']]['total_tasks'] = data[item['workDate']]
    ['total_tasks'] + 1
510 data[item['workDate']]['work_detail'].append(item['title'])
511 except Exception as e:
512     print('error', e)
513     return make_json_loads(data=data)
514     return True
```

Sink Details**Sink:** print()**Enclosing Method:** get_user_working_calendar()**File:** addons/etc_working_calendar/models/etc_working_calendar.py:512**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
509 data[item['workDate']]['total_tasks'] = data[item['workDate']]['total_tasks'] + 1
510 data[item['workDate']]['work_detail'].append(item['title'])
511 except Exception as e:
512     print('error', e)
513     return make_json_loads(data=data)
514     return True
515
```

Package: cicd**cicd/wait-for-psql.py, line 31 (System Information Leak: Internal)****Issue Details****Kingdom:** Encapsulation**Scan Engine:** SCA (Data Flow)**Source Details****Source:** __python_get_last_exception()**File:** cicd/wait-for-psql.py:24

System Information Leak: Internal**Low****Package: cicd****cicd/wait-for-psql.py, line 31 (System Information Leak: Internal)**

```
21 conn = psycopg2.connect(user=args.db_user, host=args.db_host,  
port=args.db_port, password=args.db_password, dbname='postgres')  
22 error = ''  
23 break  
24 except psycopg2.OperationalError as e:  
25 error = e  
26 else:  
27 conn.close()
```

Sink Details**Sink:** print()**File:** cicd/wait-for-psql.py:31**Taint Flags:** EXCEPTIONINFO, SYSTEMINFO

```
28 time.sleep(1)  
29  
30 if error:  
31 print("Database connection failure: %s" % error, file=sys.stderr)  
32 sys.exit(1)  
33  
34 undefined
```

Weak Cryptographic Hash (1 issue)

Abstract

Weak cryptographic hashes cannot guarantee data integrity and should not be used in security-critical contexts.

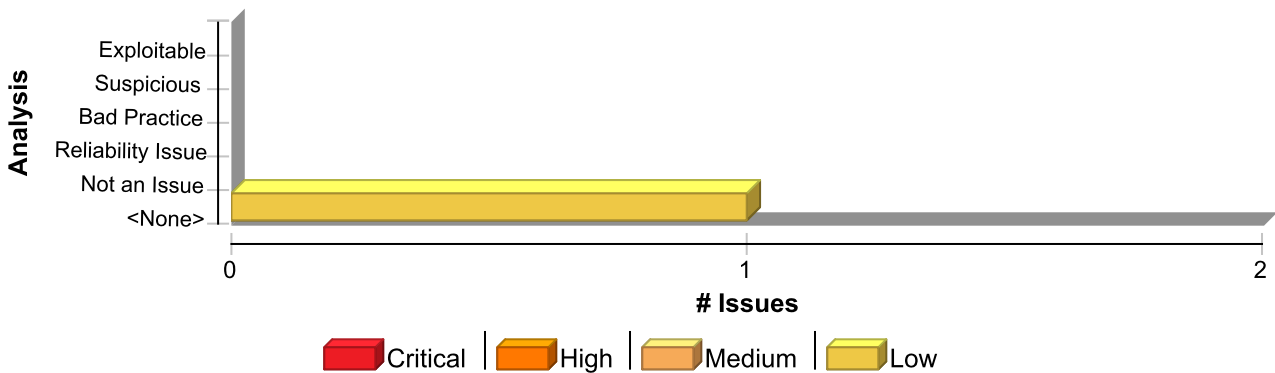
Explanation

MD2, MD4, MD5, RIPEMD-160, SHA-1 and Keccak are popular cryptographic hash algorithms often used to verify the integrity of messages and other data. However, as recent cryptanalysis research has revealed fundamental weaknesses in these algorithms, they should no longer be used within security-critical contexts. Effective techniques for breaking MD and RIPEMD hashes are widely available, so those algorithms should not be relied upon for security. In the case of SHA-1, current techniques still require a significant amount of computational power and are more difficult to implement. However, attackers have found the Achilles' heel for the algorithm, and techniques for breaking it will likely lead to the discovery of even faster attacks.

Recommendation

Discontinue the use of MD2, MD4, MD5, RIPEMD-160, SHA-1 and Keccak for data-verification in security-critical contexts. Currently, SHA-224, SHA-256, SHA-384, SHA-512, and SHA-3 are good alternatives. However, these variants of the Secure Hash Algorithm have not been scrutinized as closely as SHA-1, so be mindful of future research that might impact the security of these algorithms.

Issue Summary



Engine Breakdown

	SCA	WebInspect	SecurityScope	Total
Weak Cryptographic Hash	1	0	0	1
Total	1	0	0	1

Weak Cryptographic Hash

Low

Package: addons.queue_job.job

addons/queue_job/job.py, line 93 (Weak Cryptographic Hash)

Issue Details

Kingdom: Security Features
Scan Engine: SCA (Semantic)



Weak Cryptographic Hash

Low

Package: addons.queue_job.job

addons/queue_job/job.py, line 93 (Weak Cryptographic Hash)

Sink Details

Sink: sha1()

Enclosing Method: identity_exact()

File: addons/queue_job/job.py:93

Taint Flags:

```
90 Usually you will probably always want to include at least the name of the
91 model and method.
92 """
93 hasher = hashlib.sha1()
94 hasher.update(job_.model_name.encode("utf-8"))
95 hasher.update(job_.method_name.encode("utf-8"))
96 hasher.update(str(sorted(job_.recordset.ids)).encode("utf-8"))
```

